DoS: Denial of Service
DDoS: Distributed Denial of Service
Hardware hacking
IoT security
Physical security

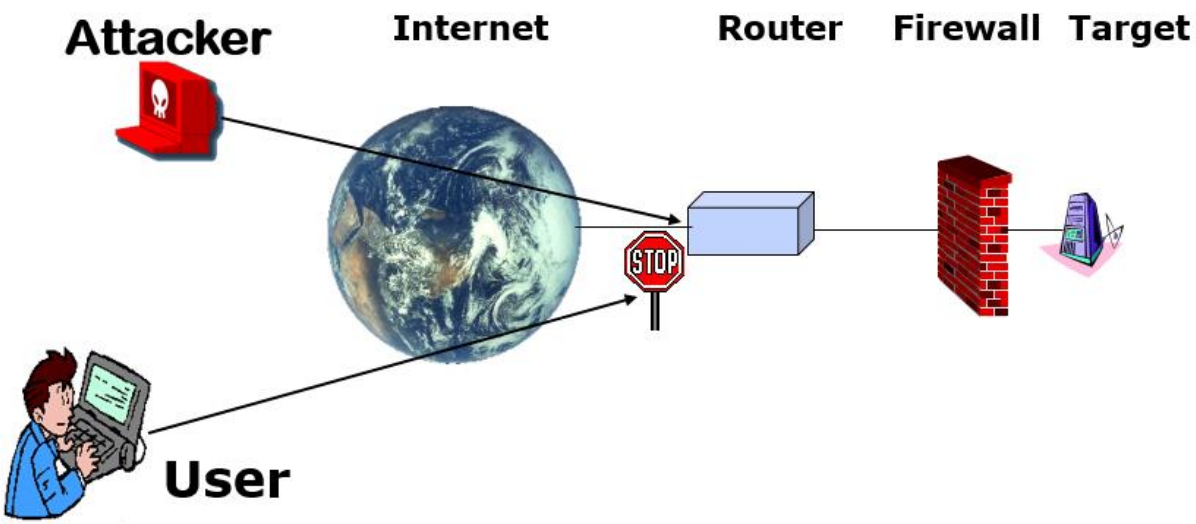
Carsten Jørgensen
Department of Computer Science

DIKU 3. oktober 2018

What is DoS

Taking out sites – even large sites - with little computing work

DoS vs. DDoS



What is DoS

Attacks against availability

Two basic classes:

Magic packets – protocol attacks or design flaw that allows one machine to disrupt a service

DoS Flood – botnet used to generate flood of data

Amplification and reflection – small number of packets from attacker -> big effect

DoS works (very well), but it is not sophisticated

The Internet is not designed to handle DDoS attacks

Nothing new:

If you have a router with a 10Gbps port and an attacker sends you 11Gbps of attack traffic, no amount of intelligent software or hardware will allow you to stop the attack if the network link is completely saturated

Why?

Attacks against availability

- Extortion: Online gambling, florists on Valentines day etc.
- Often an initial low-level attack and a warning that a larger attack will be carried out unless Bitcoin ransom is paid

Cloud computing cost-attacks

Why?

SAMFUND

Pakkefirma ramt af cyberangreb på årets travleste pakkedag

19. dec. 2017, 20:40

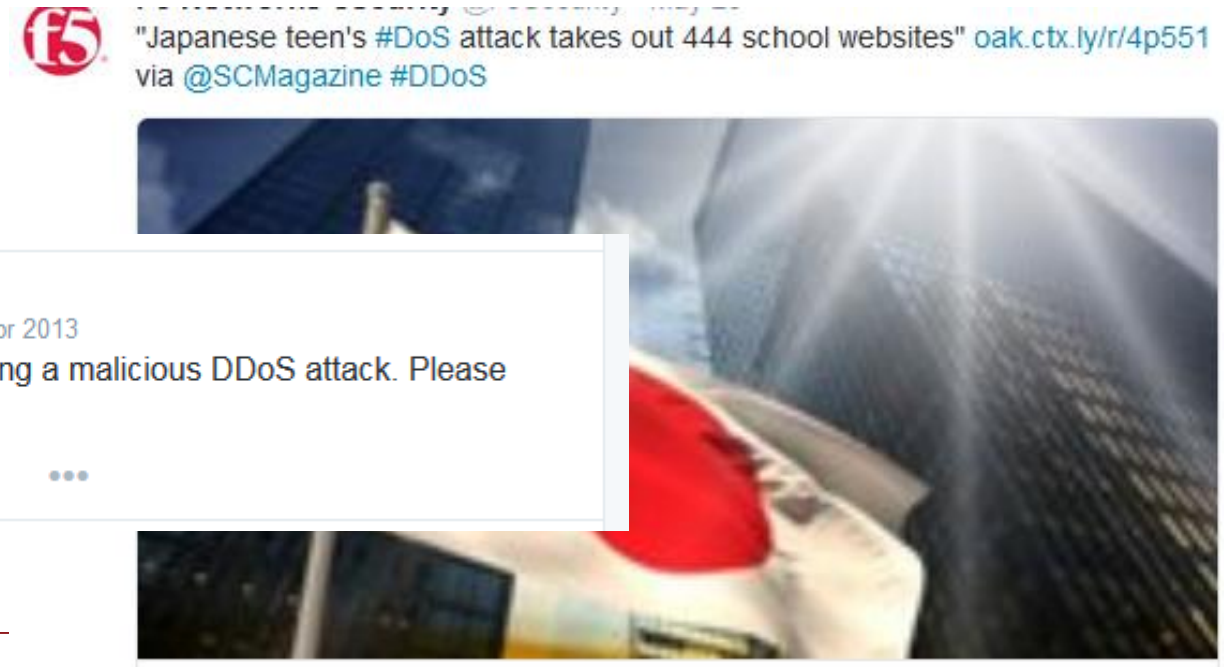
Gladsaxe Distributionscenter var fyldt med pakker på den dag, som Postnord forventer bliver en af de

MEST

Why?

Part of serious attacks, hiding tracks

"Fun" or anger
Curiosity
Not understanding how DoS (or the internet) works



Hacktivism

version2

IT-NYHEDER | BLOGS | IT-JOB | IT-FIRMAER | WHITEPAPERS | KURSER

EMNER *Hacking*

Se kommentarer (27)

3F's hjemmeside kæmper mod gentagne DDoS-angreb

Hos fagforeningen 3F kæmper man i øjeblikket en hård kamp mod et DDoS-angreb mod hjemmesiden, som begyndte onsdag aften.

Af Theis Holtz Hansen Fredag, 20. juli 2012 - 11:04

Fagforeningen 3F's hjemmeside bliver i øjeblikket oversvømmet med forespørgsler, der har til formål at lægge siden ned. Altså et såkaldt DdoS-angreb.

Angrebet er angiveligt sat i værk af Twitter-brugeren Elan0r1, som med en statusopdatering tager ansvaret for angrebet. Ifølge opdateringen sker angrebet i sympati for Restaurant Vejlegården, som 3f har blokeret i en overenskomstkonflikt.

DoS is cheap - and easy for the attacker

NEM ID

PRIVAT | ERHVERV | MYNDIGHEDER | OM NEMID | DIGITAL SIGNATUR

Om NemID

Forside / Om NemID / Aktuelt

- Aktuelt
  - Nyhedsarkiv
  - Nyhedsbrev om NemID
  - Statistik om NemID
  - Driftsstatus
  - Driftsstatistik for NemID
- Hvad er NemID?
- Hvem kan få NemID?
- Er NemID obligatorisk?
- Her kan du bruge NemID
- Sikkerhed
- Regler
- Videreudvikling af NemID
- Om dette websted
- Ofte stillede spørgsmål

NemID udsat for DDoS-angreb

11. april 2013
Publiceret af: Digitaliseringsstyrelsen

Torsdag morgen fra ca. kl. 5-8 har det været svært eller umuligt at logge på med NemID i både netbanken og på offentlige og private hjemmesider.

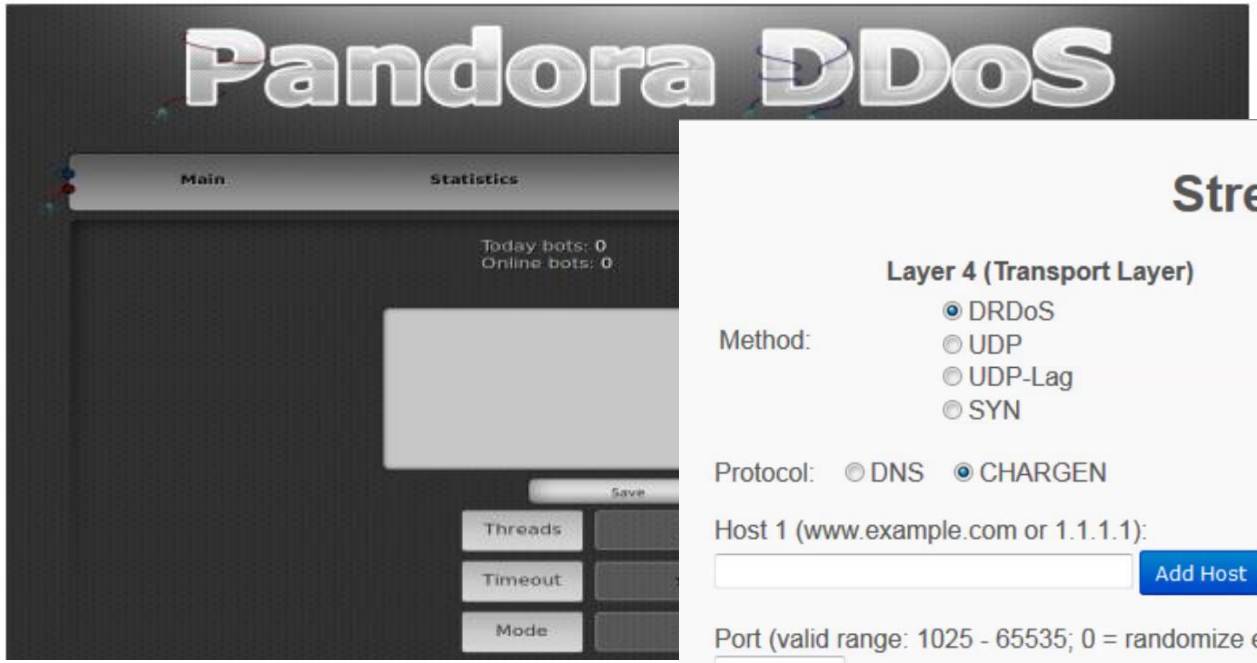
Lignende hændelser fandt sted den 24. og 25. marts.

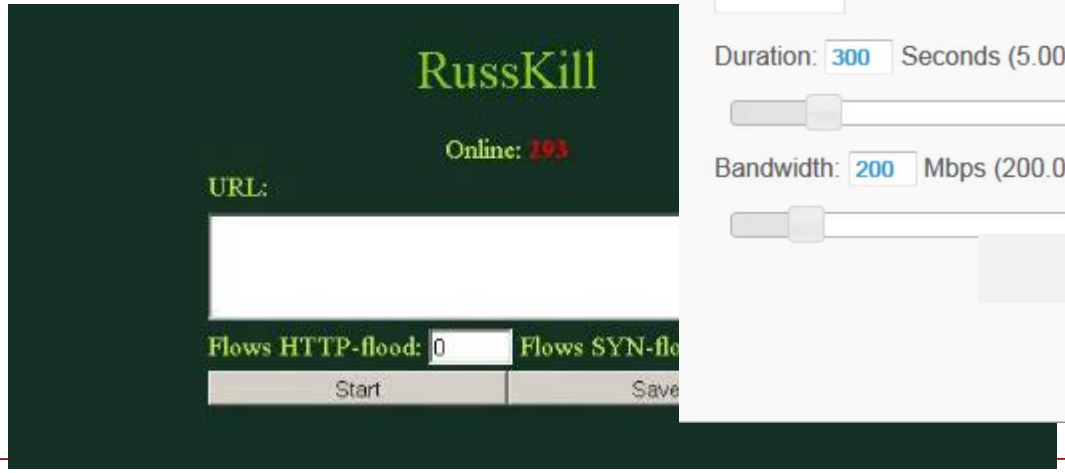
Adgangen er stadig ustabil, og der arbejdes på at løse problemerne.

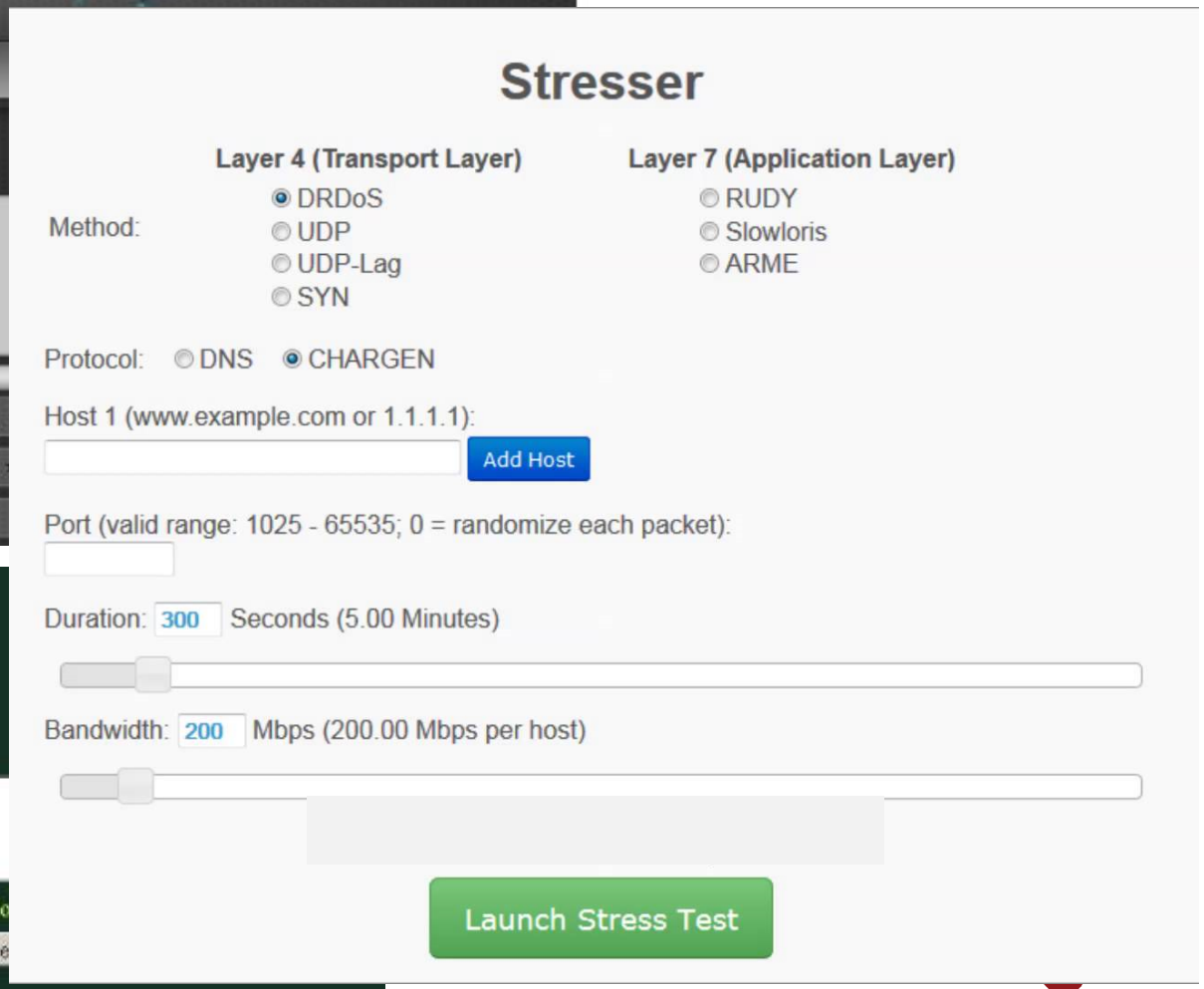
Årsagen til problemerne skyldes, at it-kriminelle udfører det, der kaldes et DDoS-angreb mod NemID.

DDoS-angreb betyder kort fortalt, at it-kriminelle via et stort netværk af computere sender så mange forespørgsler til NemID-systemet, at systemet

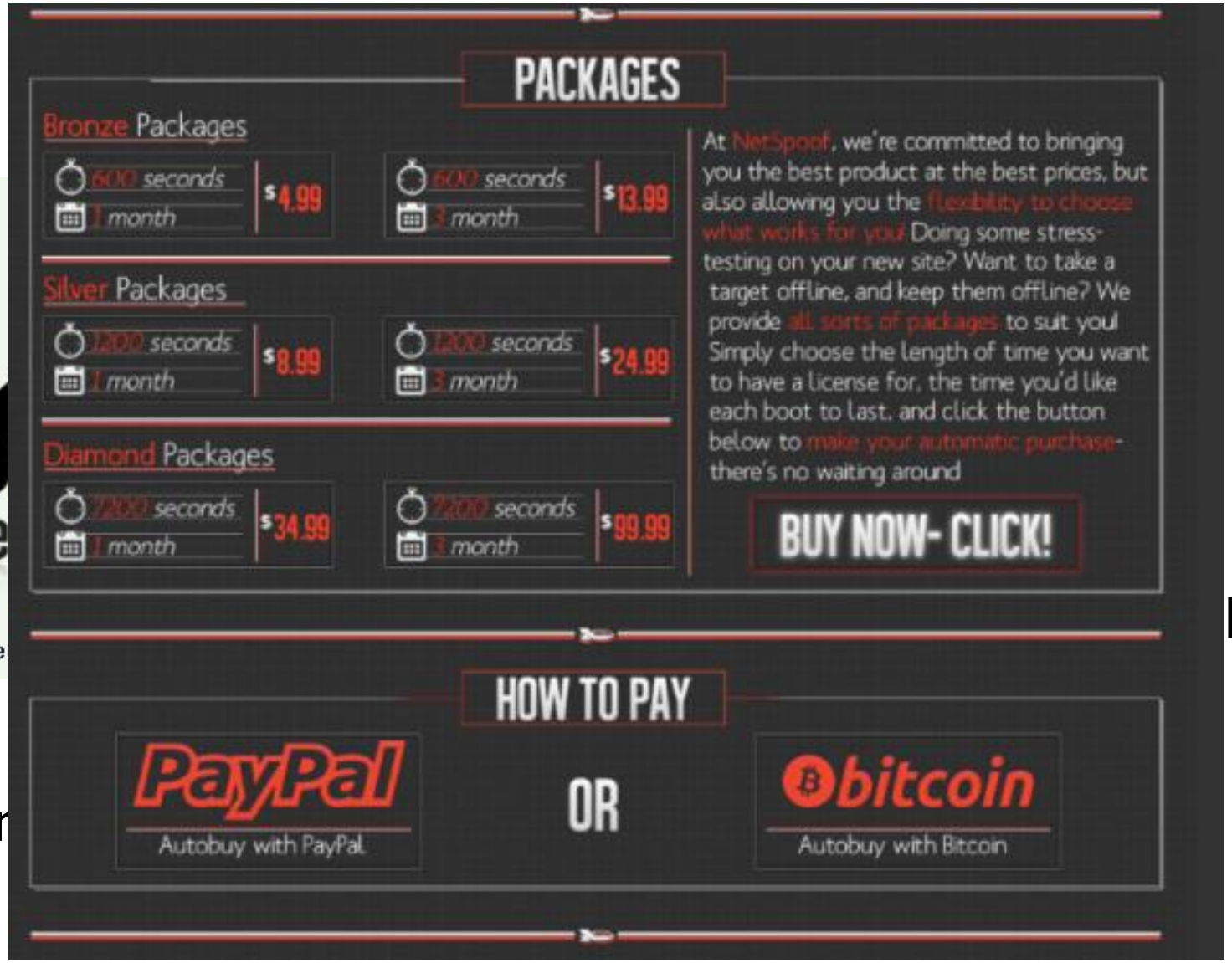
DoS is easy for the attacker





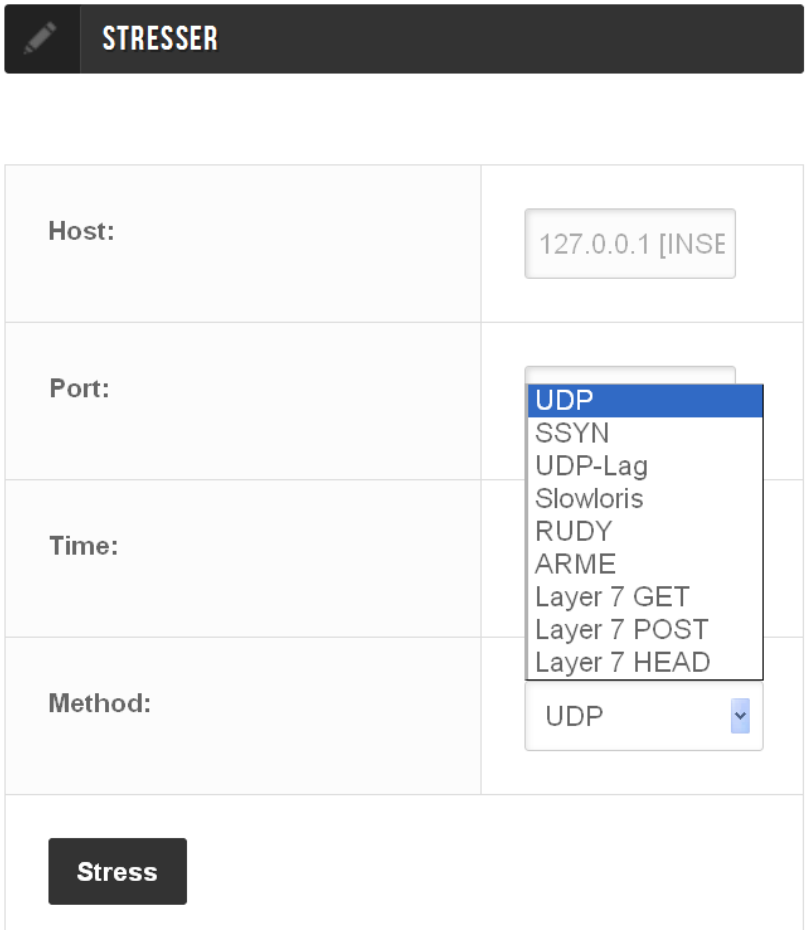


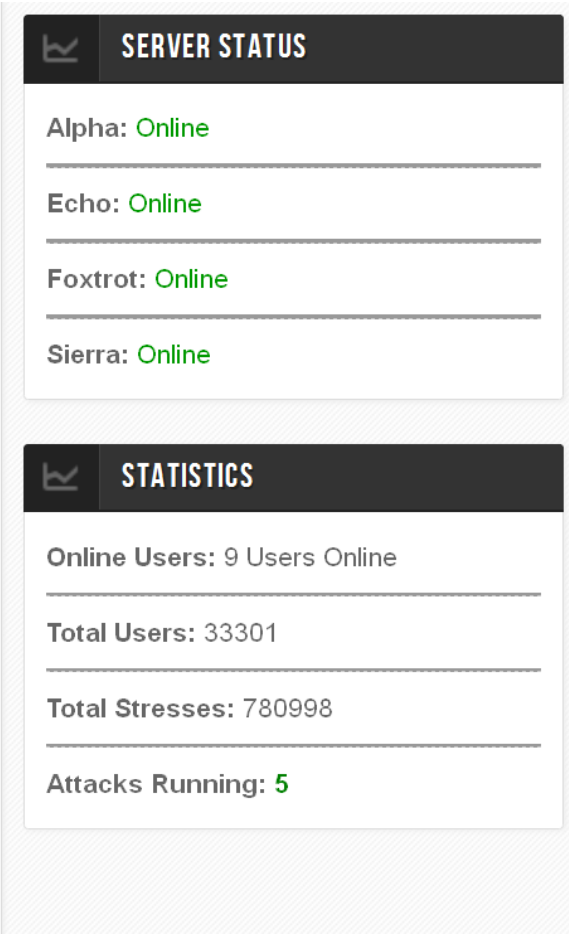
DoS is cheap - and easy for the attacker



Stressers and booters

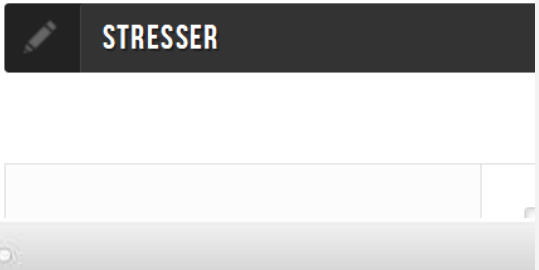
”Stressers” and ”booters”

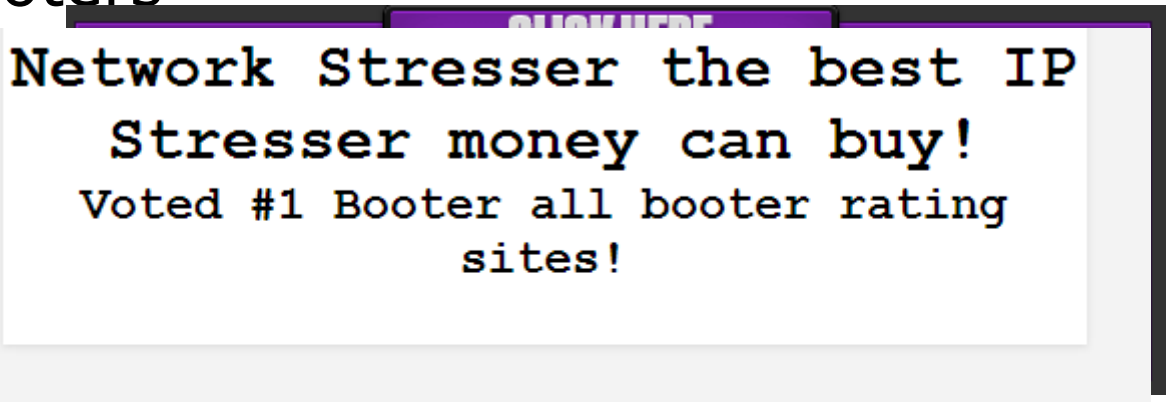


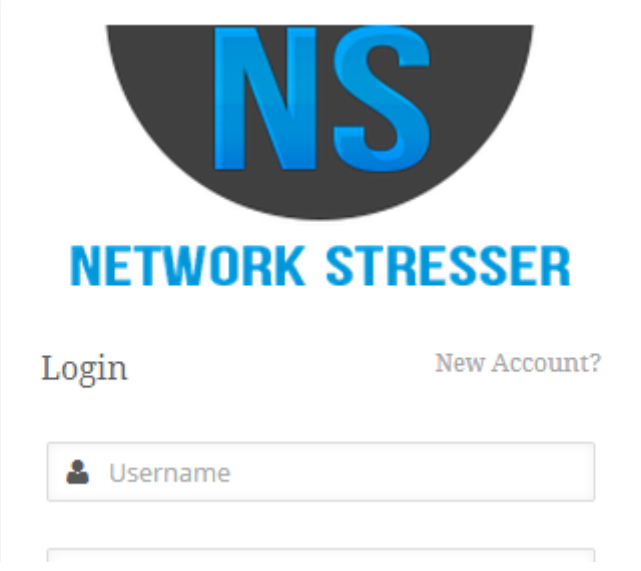


Stressers and booters

"Stressers" and "booters"







What is DoS

DoS can take place at any layer

Most common:
IP/TCP/UDP/ICMP
(Layer 3 and 4 – transport and network)

Applications
(Layer 7 attacks)

Denial-of-Service (DoS): “Magic packets”

Denial-of-Service (DoS)

Ping of Death, TearDrop, NewTear, Nestea2, Pepsi, Stream, HAVOC, Smurf, Fraggle, SYN-flood, NULL-flood, ACK-flood, Data-flood, Teletubbies Flood Network, Trin00, Hammer, Slowloris, ARME

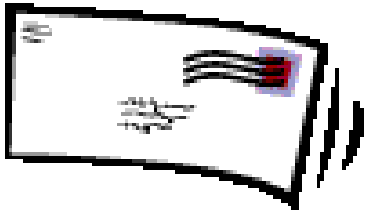
DoS: “Magic Packets”

Unexpected and unwanted traffic

Malformed packets:
overlapping, fragmented, too large, too small, ‘strange’ options

Result: Crashing host or service or high CPU load so other requests cannot be serviced

“Magic Packets” - Land



To: Peter

From: Peter

DoS: “Magic Packets”

Land - same sender and recipient:

Expected: TO: A:port 80, FROM **B**:port 2304

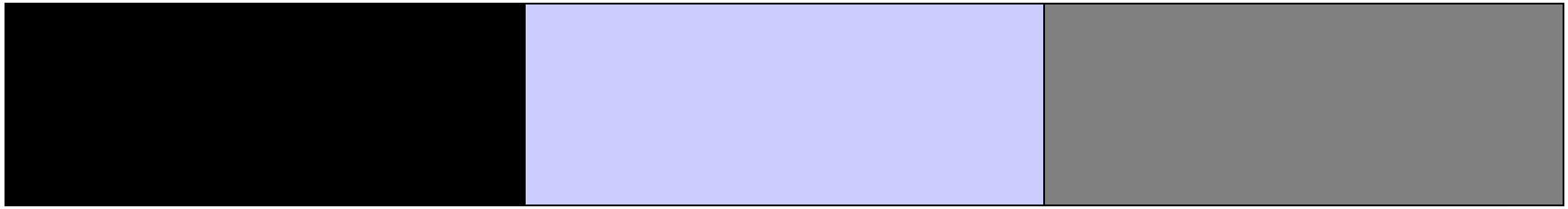
Recieves: TO: A:port 80, FROM **A**:port 80

DoS: “Magic Packets”

ICMP ‘Ping of Death’:

ICMP-packet max length:

Packet longer than max length after assembly:



DoS: “Magic Packets”

TearDrop: Overlapping packets:

Expected: large packet, reassembled:

Recieved: large overlapping packet:

DoS: “Magic Packets”

Overlapping packets:

expected: large packet, reassembled:

Received: parts of packet missing, but claimed to be correct:

DoS: “Magic Packets”

Don’t fragment flag set, + ‘more fragments follows’ flag set:

“Packet is NOT fragmented”

“NEXT fragment follows”

DoS and DDoS

Modern operating systems are (currently) not vulnerable

Internet of Things etc could change that

At the moment flooding attacks are much more common

Bandwidth Saturation

DoS: Bandwidth Saturation

Sending more traffic than the network/server can handle

Smurf, Fraggle, SYN-flooding, Stream, UDP-flood, etc, etc, etc

Saturates network router or network uplink

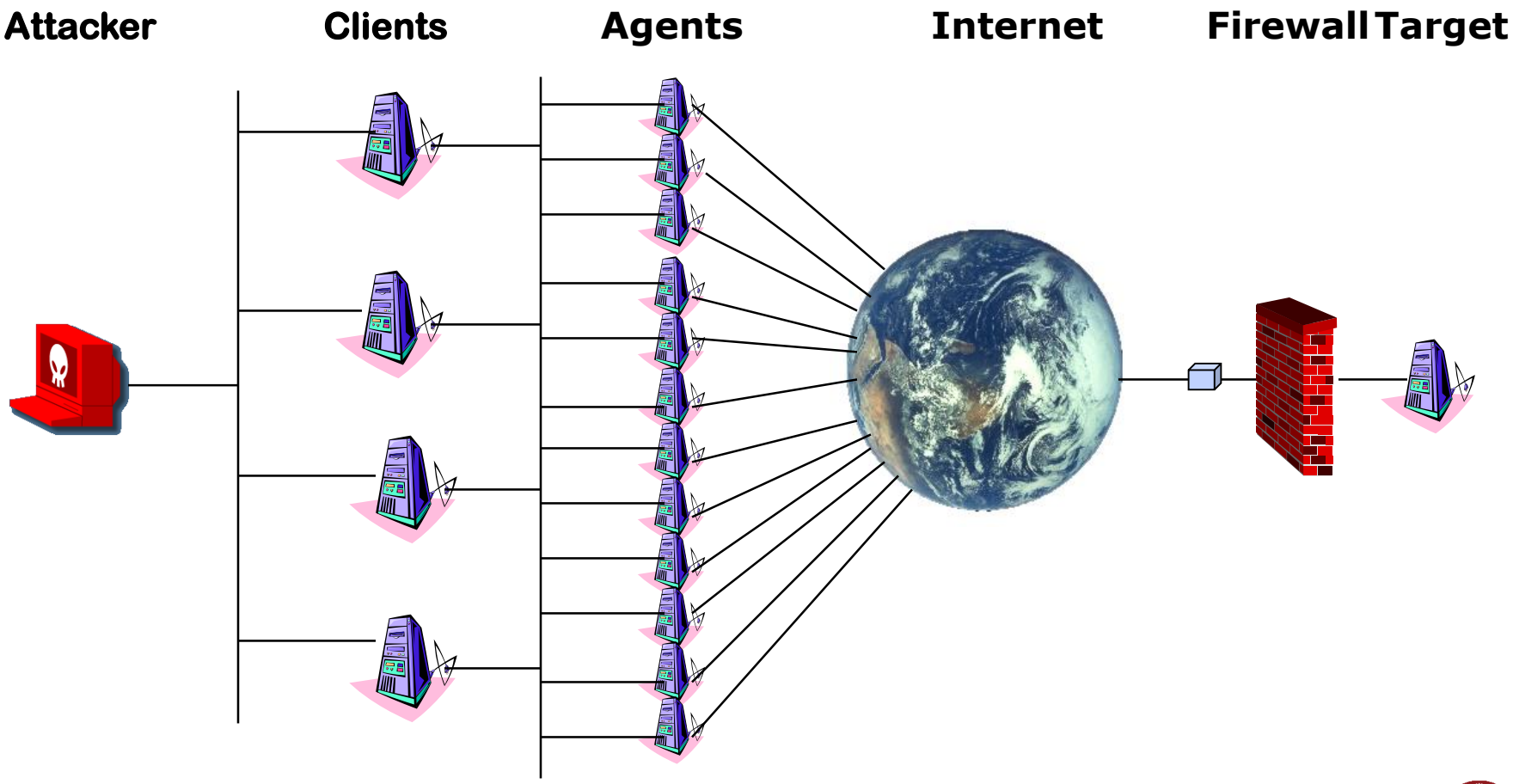
Stopping others from accessing the network or host

Distributed Denial of Service and BotNets

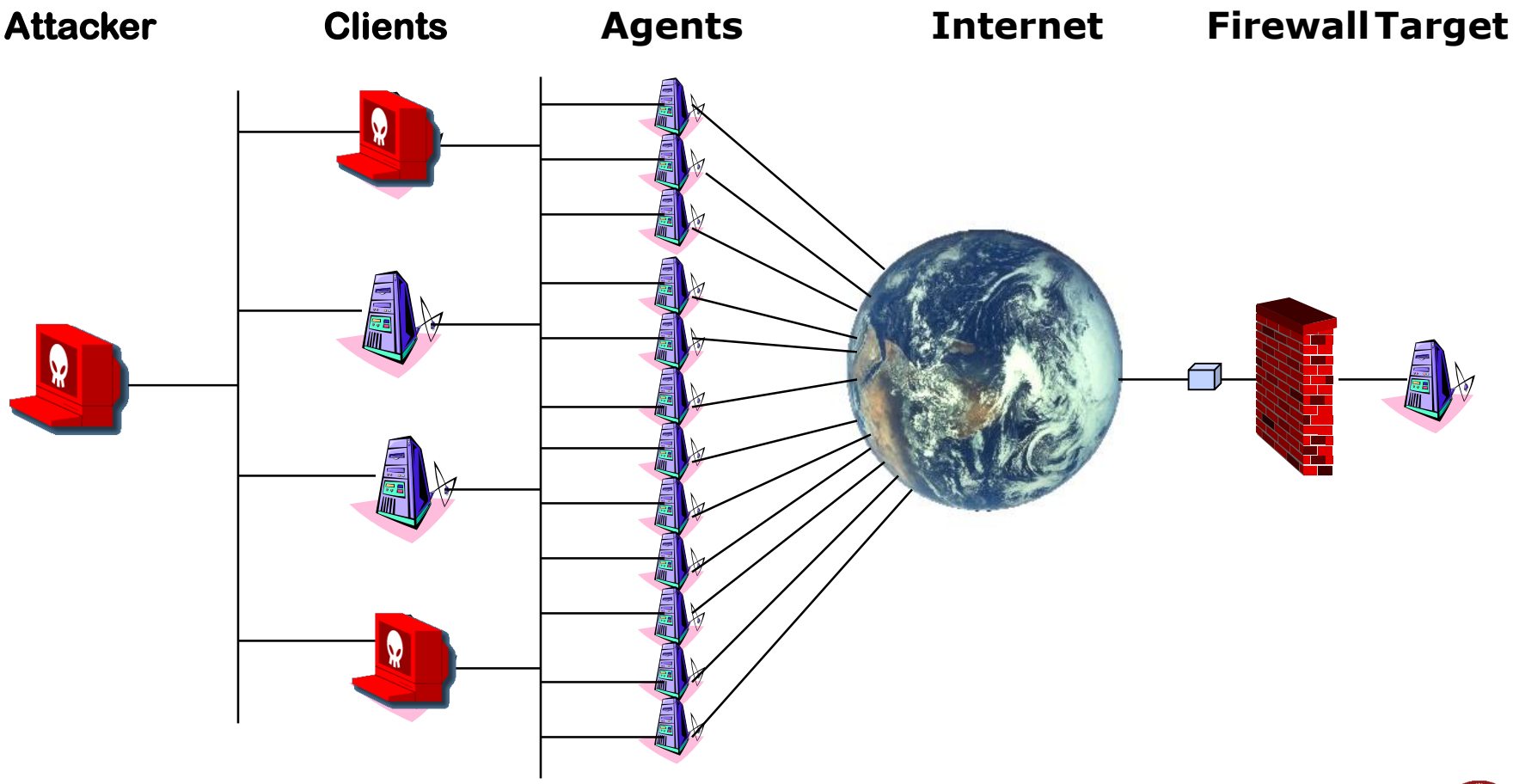
Can be groups of individuals working together (hacktivism)

Most commonly:
Botnets of compromised PCs or compromised servers

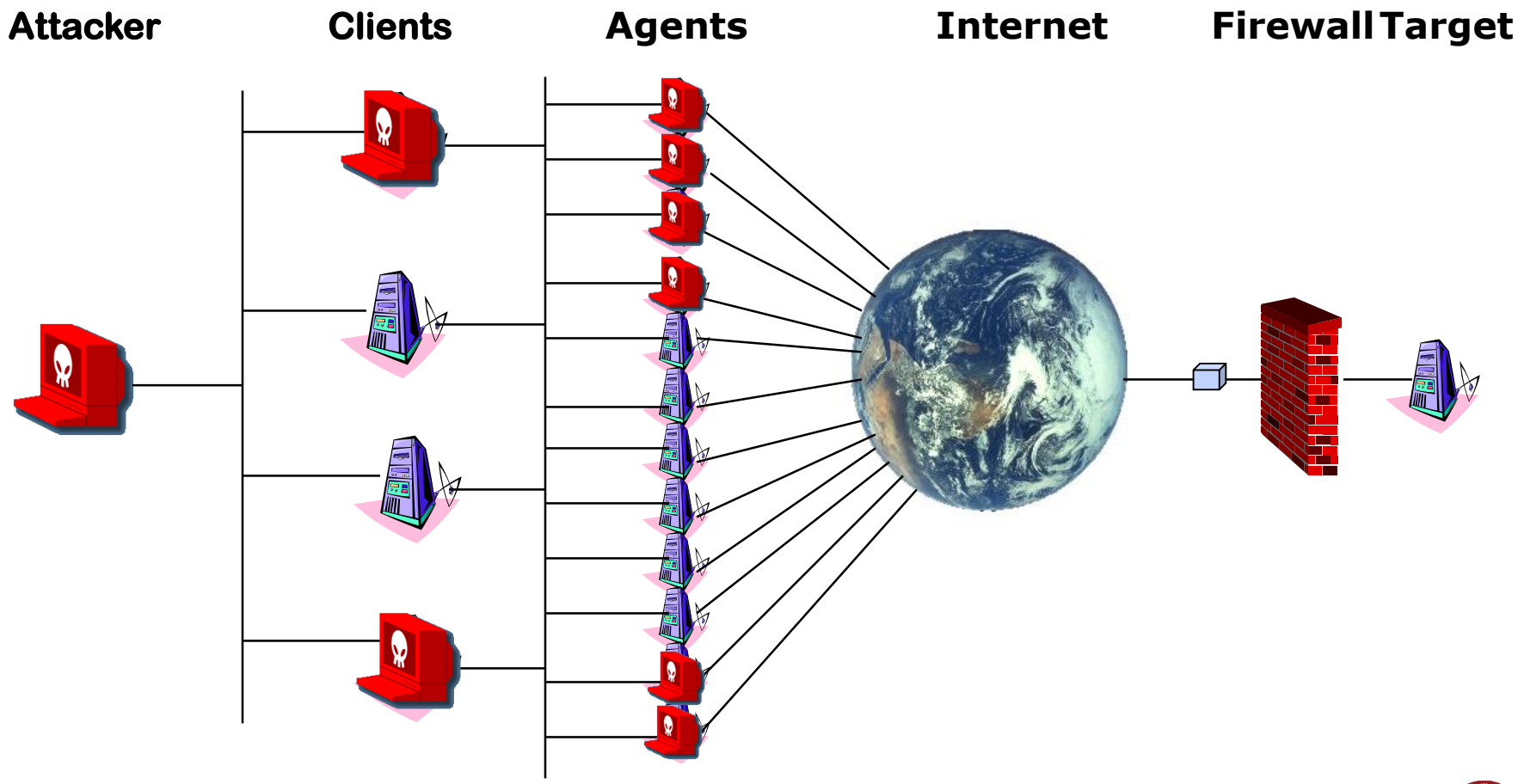
Distributed Denial-of-Service Attack



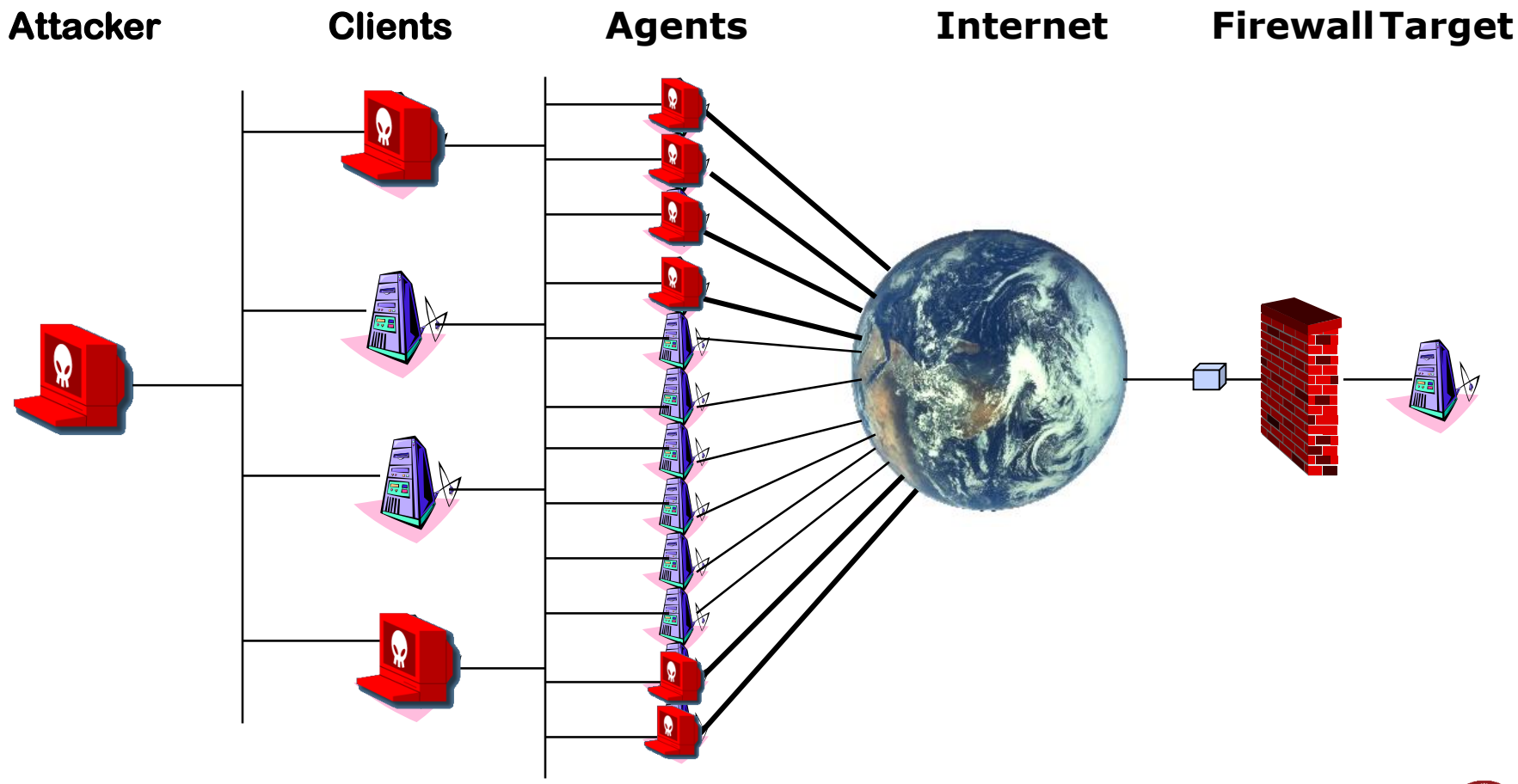
Distributed Denial-of-Service Attack



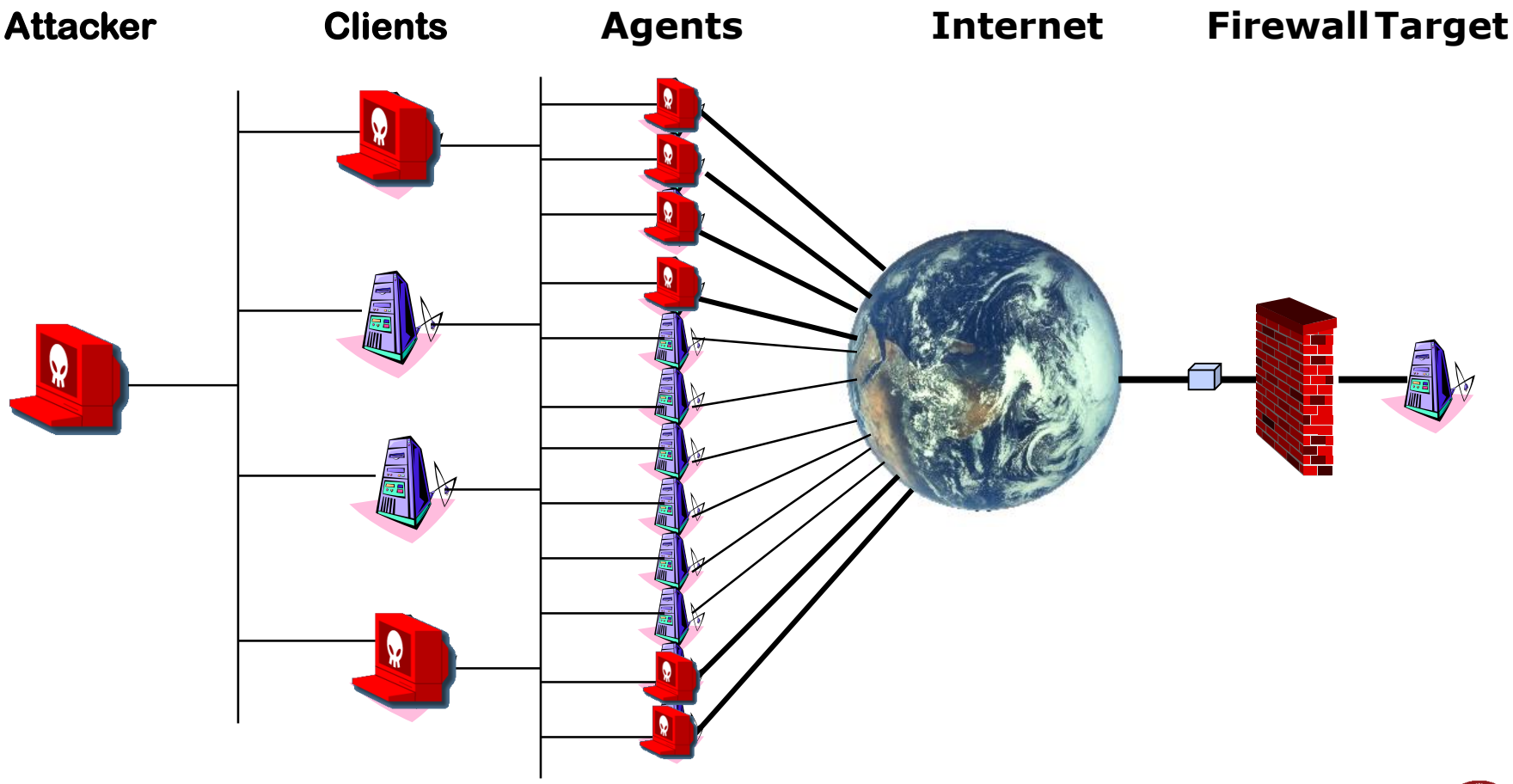
Distributed Denial-of-Service Attack



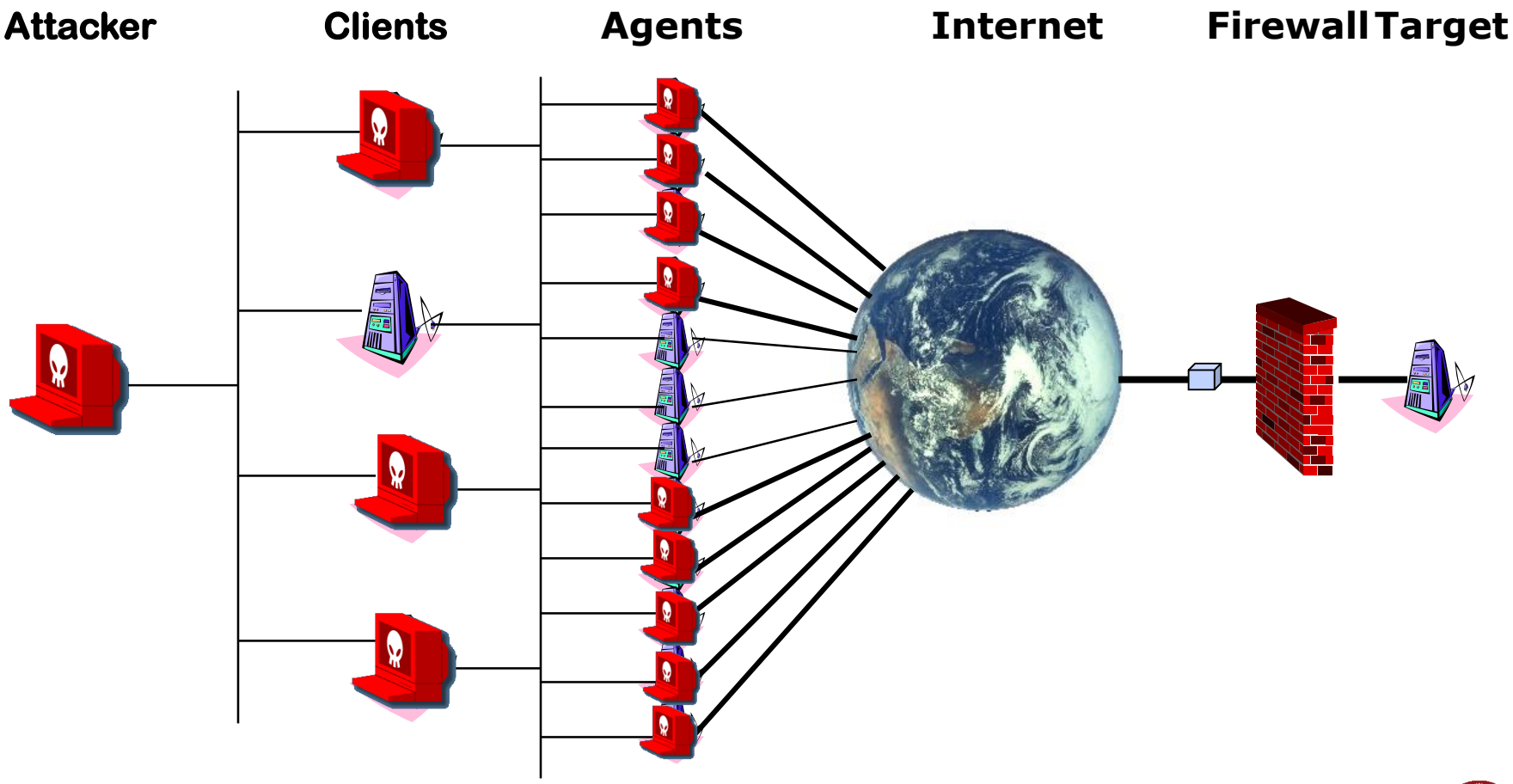
Distributed Denial-of-Service Attack



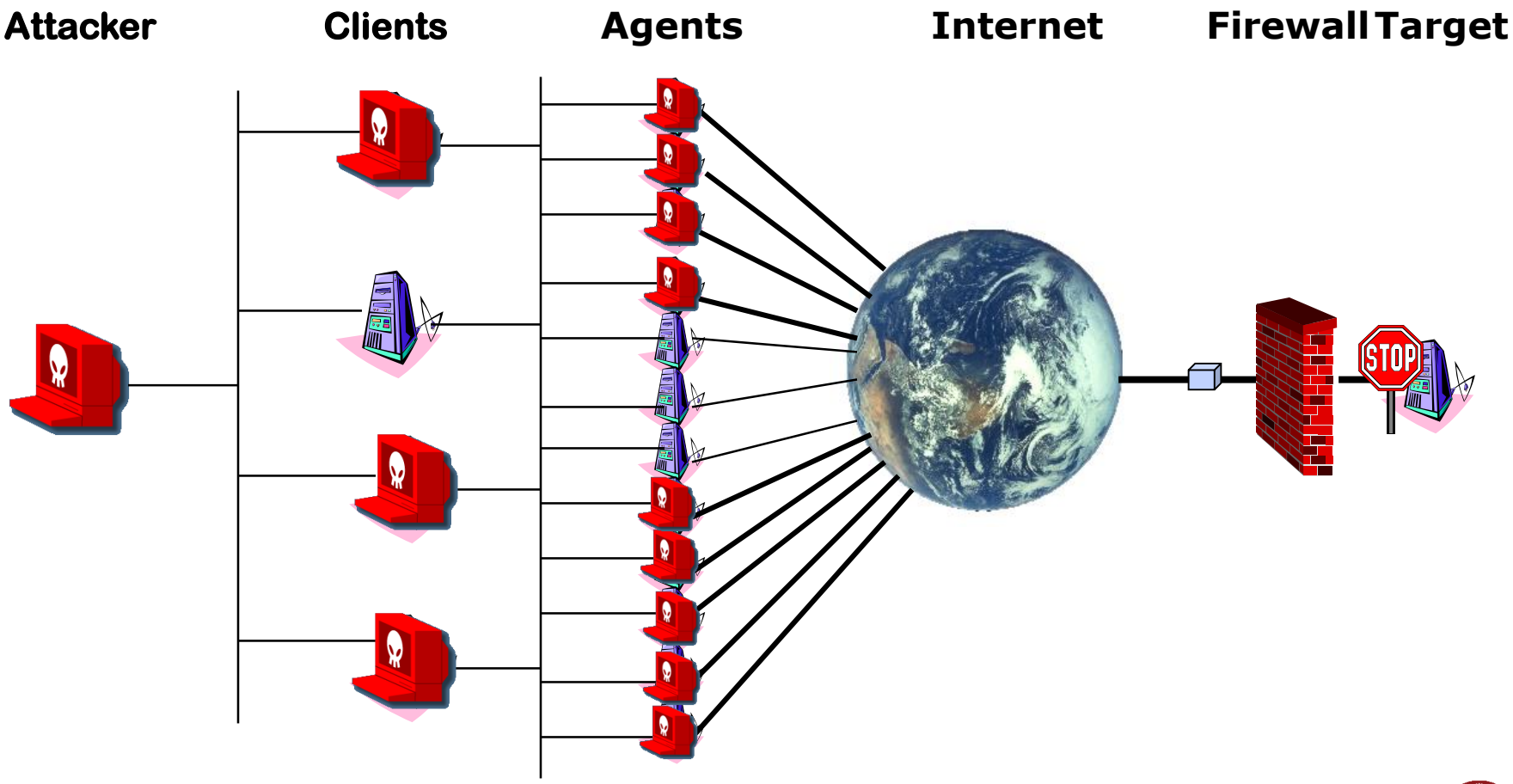
Distributed Denial-of-Service Attack



Distributed Denial-of-Service Attack



Distributed Denial-of-Service Attack



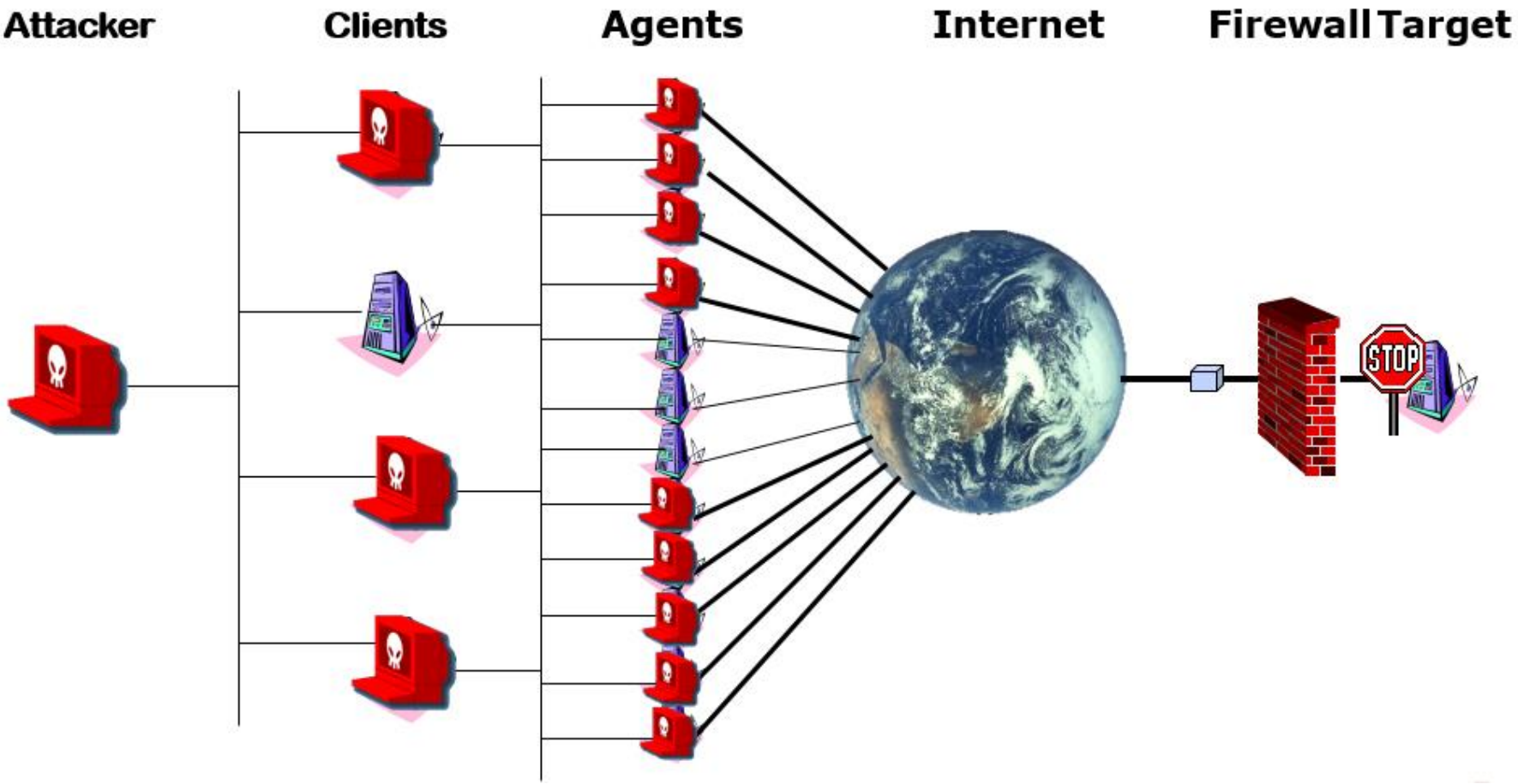
Tribe Flood Net 2000

Terminal <4>

Fil Indstillinger Hjælp

```
[root@t3 tfn2k]# ./tfn
usage: ./tfn <options>
[-P protocol]   Protocol for server communication. Can be ICMP, UDP or TCP.
                Uses a random protocol as default
[-D n]          Send out n bogus requests for each real one to decoy targets
[-S host/ip]    Specify your source IP. Randomly spoofed by default, you need
                to use your real IP if you are behind spoof-filtering routers
[-f hostlist]   Filename containing a list of hosts with TFN servers to contact
[-h hostname]   To contact only a single host running a TFN server
[-i target string]      Contains options/targets separated by '@', see below
[-p port]               A TCP destination port can be specified for SYN floods
<-c command ID> 0 - Halt all current floods on server(s) immediately
                1 - Change IP antispoof-level (evade rfc2267 filtering)
                    usage: -i 0 (fully spoofed) to -i 3 (/24 host bytes spoofed)
                2 - Change Packet size, usage: -i <packet size in bytes>
                3 - Bind root shell to a port, usage: -i <remote port>
                4 - UDP flood, usage: -i victim@victim2@victim3@...
                5 - TCP/SYN flood, usage: -i victim@... [-p destination port]
                6 - ICMP/PING flood, usage: -i victim@...
                7 - ICMP/SMURF flood, usage: -i victim@broadcast@broadcast2@...
                8 - MIX flood (UDP/TCP/ICMP interchanged), usage: -i victim@...
                9 - TARGA3 flood (IP stack penetration), usage: -i victim@...
                10 - Blindly execute remote shell command, usage -i command
[root@t3 tfn2k]#
```

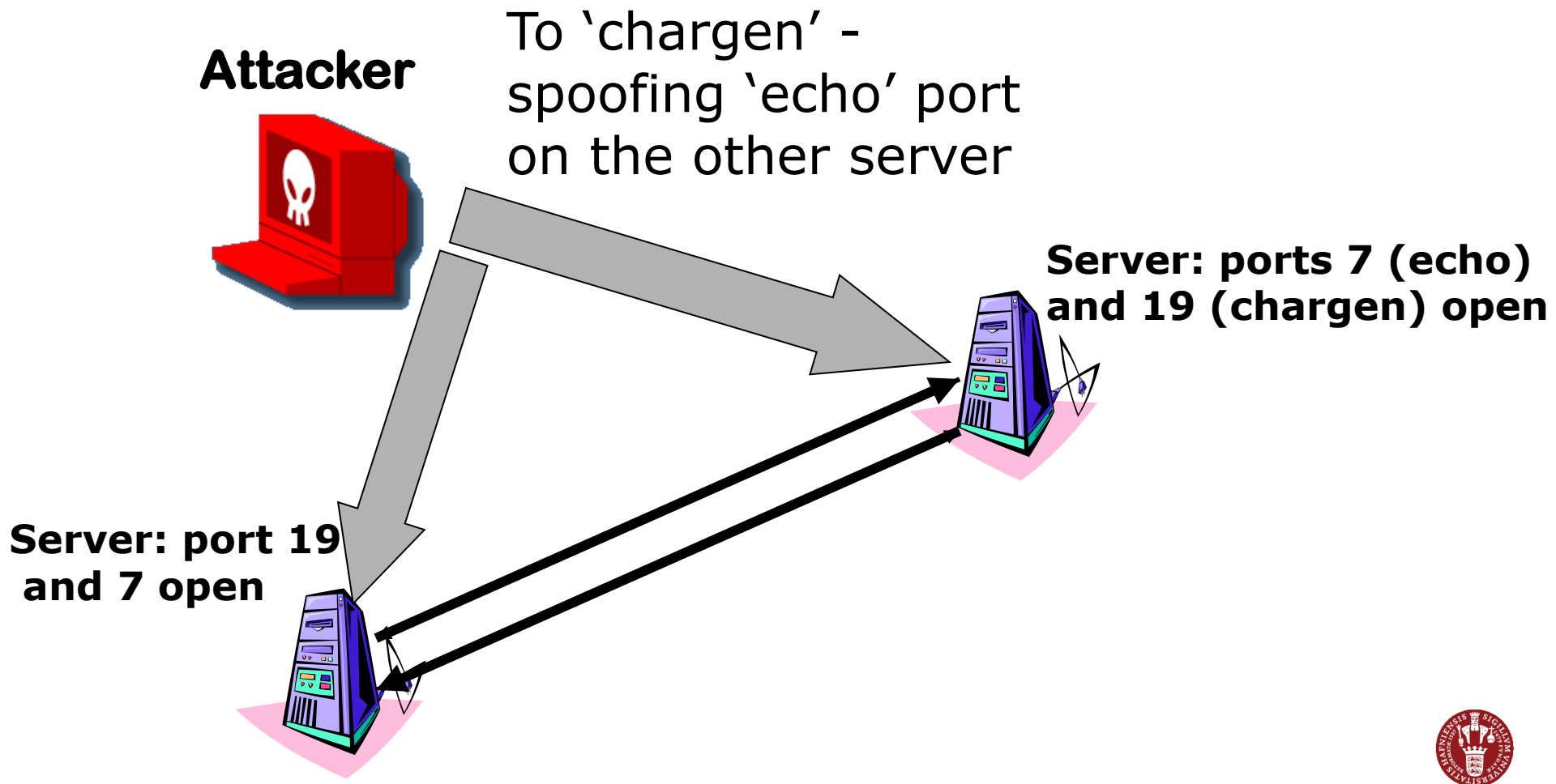
Problems for the attacker?



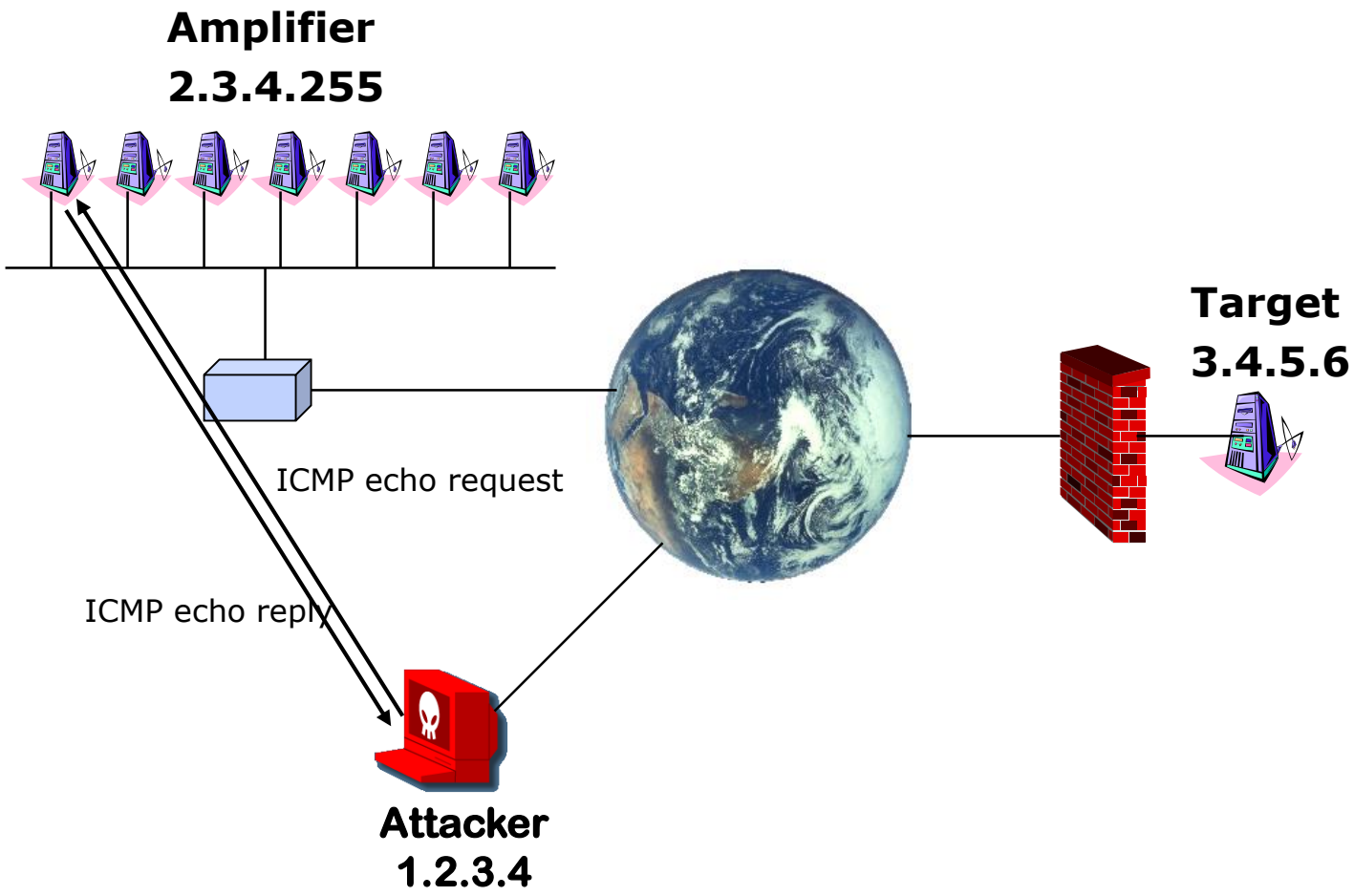
Attacker risk assessment…

Amplification DDoS

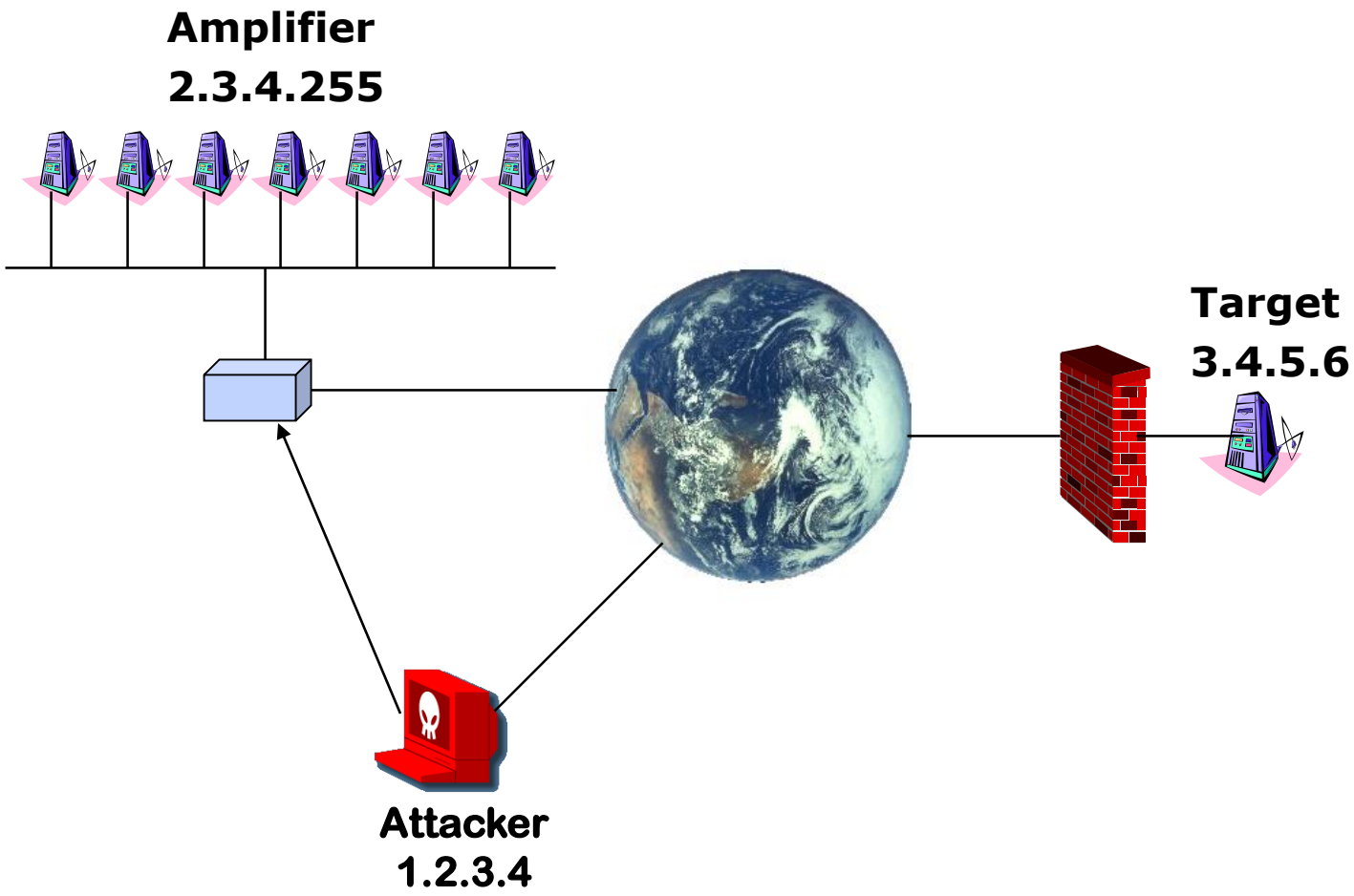
Chargen, echo etc



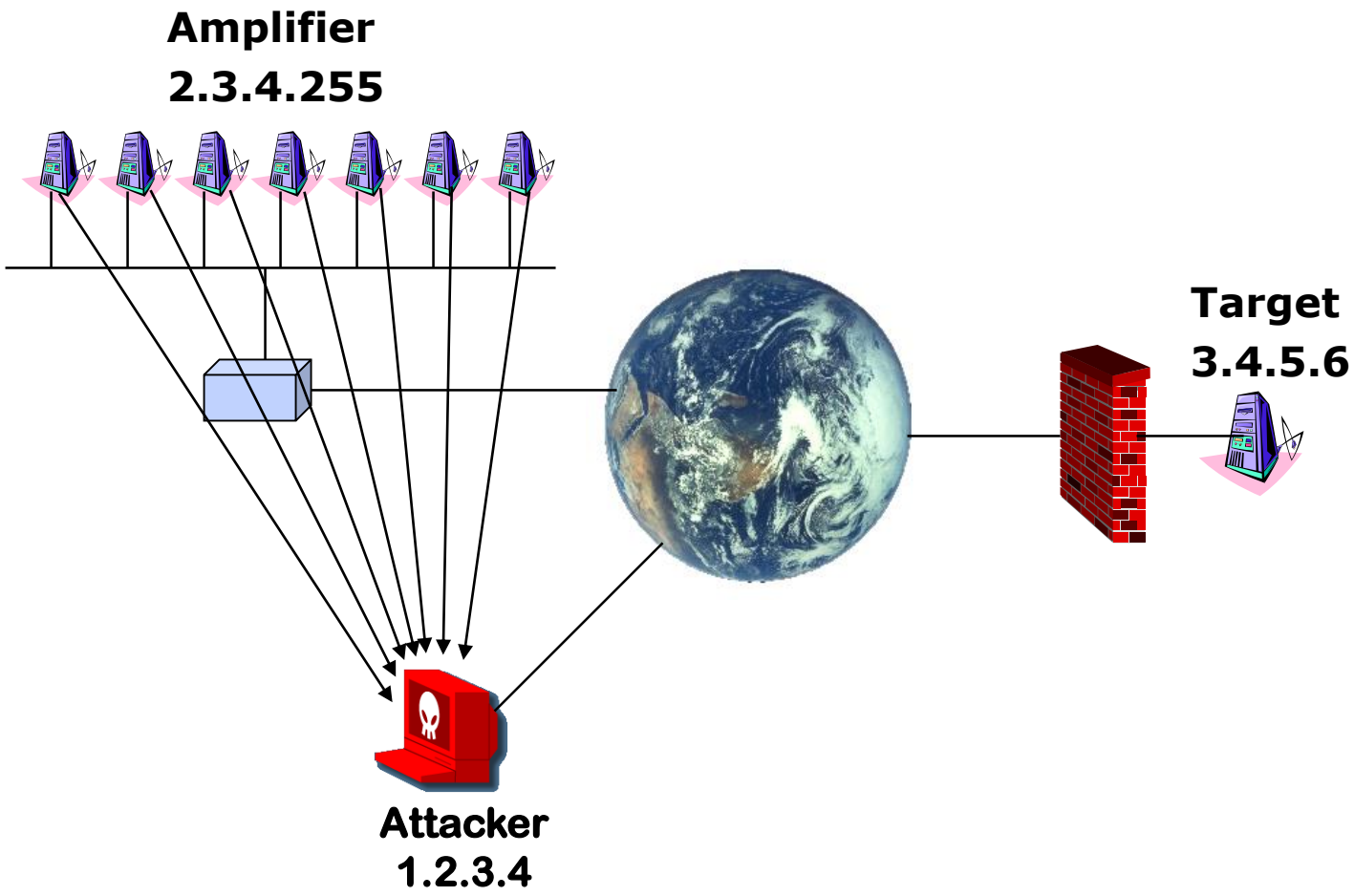
Smurf (and Fraggle):



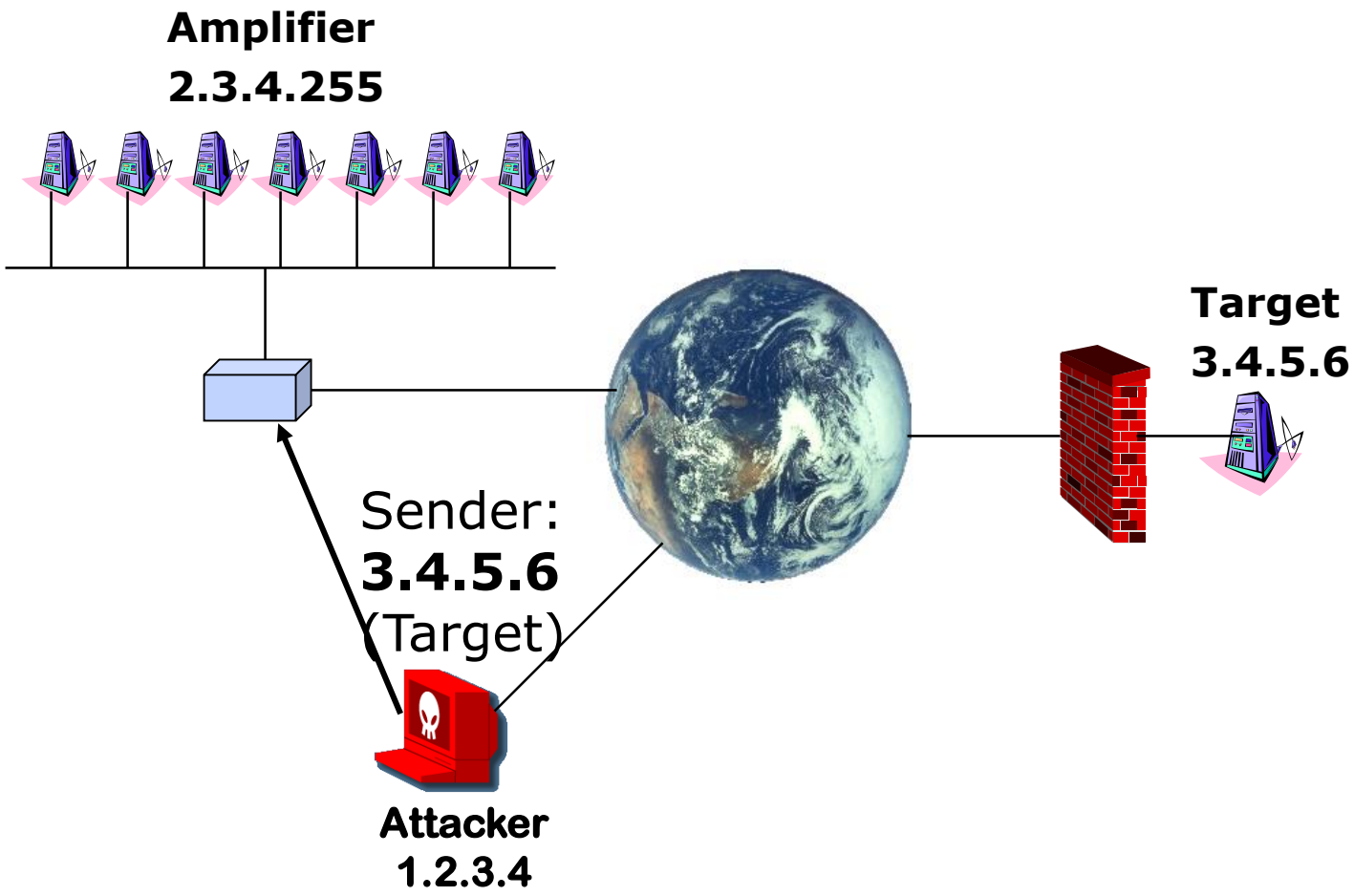
Smurf (and Fraggle):



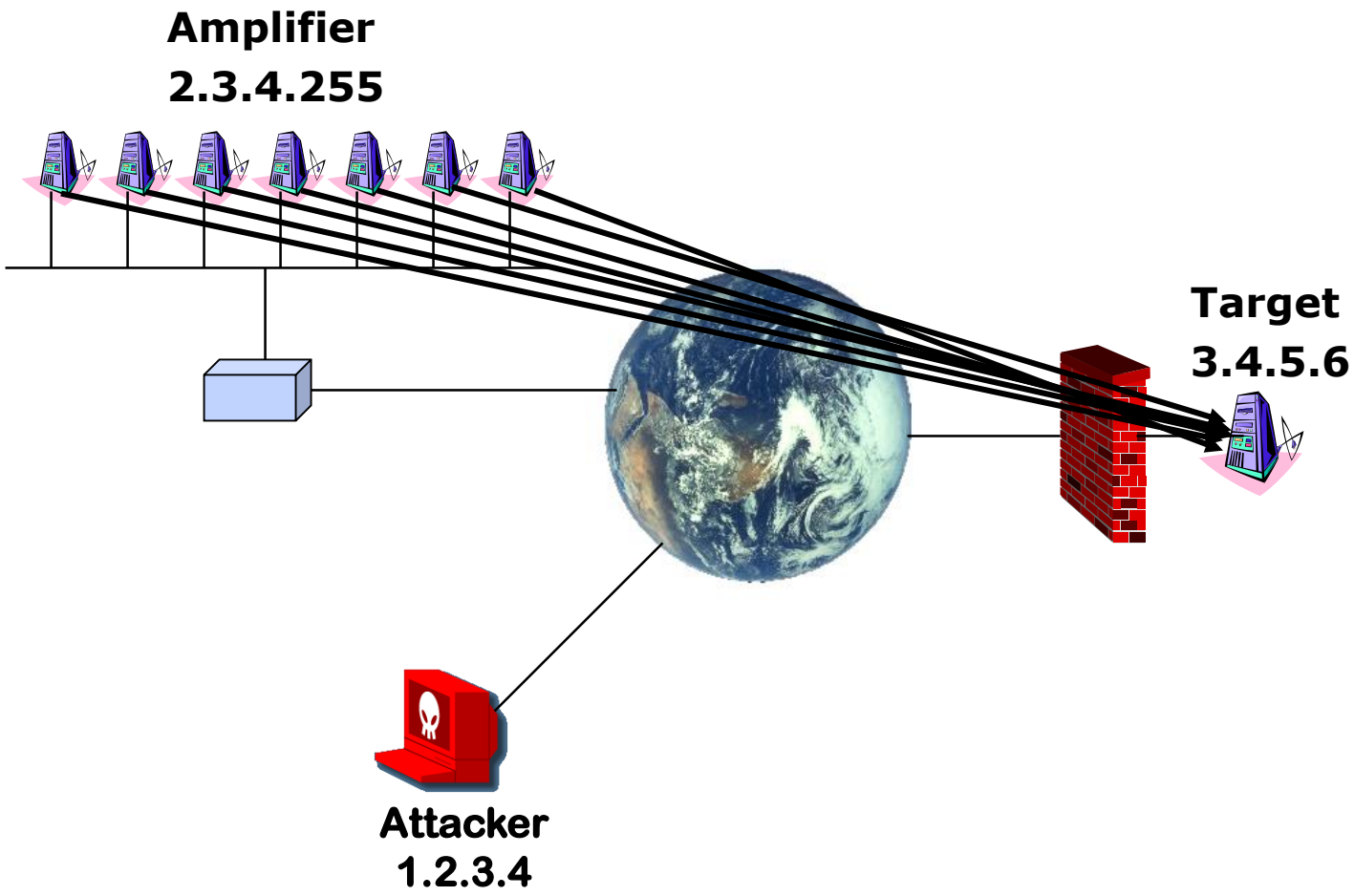
Smurf (and Fraggle):



Smurf (and Fraggle):



Smurf (and Fraggle):



Smurf attack

768 kb/s, 100 computers = 76.8 Mb/s

DNS amplification attacks

A 64 byte query results in a 3,223 byte zone response (50-times amplification)

dig ANY isc.org @x.x.x.x +edns=0

Query is sent with a spoofed source address.
DNS queries are most often UDP

Amplification attacks are very common

(Smurf: 768 kb/s, 100 computers = 76.8 Mb/s)

DNS: 100 to 500 Gbps is now common

NTP – Network Time Protocol
SSDP – Simple Service Discovery protocol

Internet of Things cameras etc.

Use your risk assessment knowledge

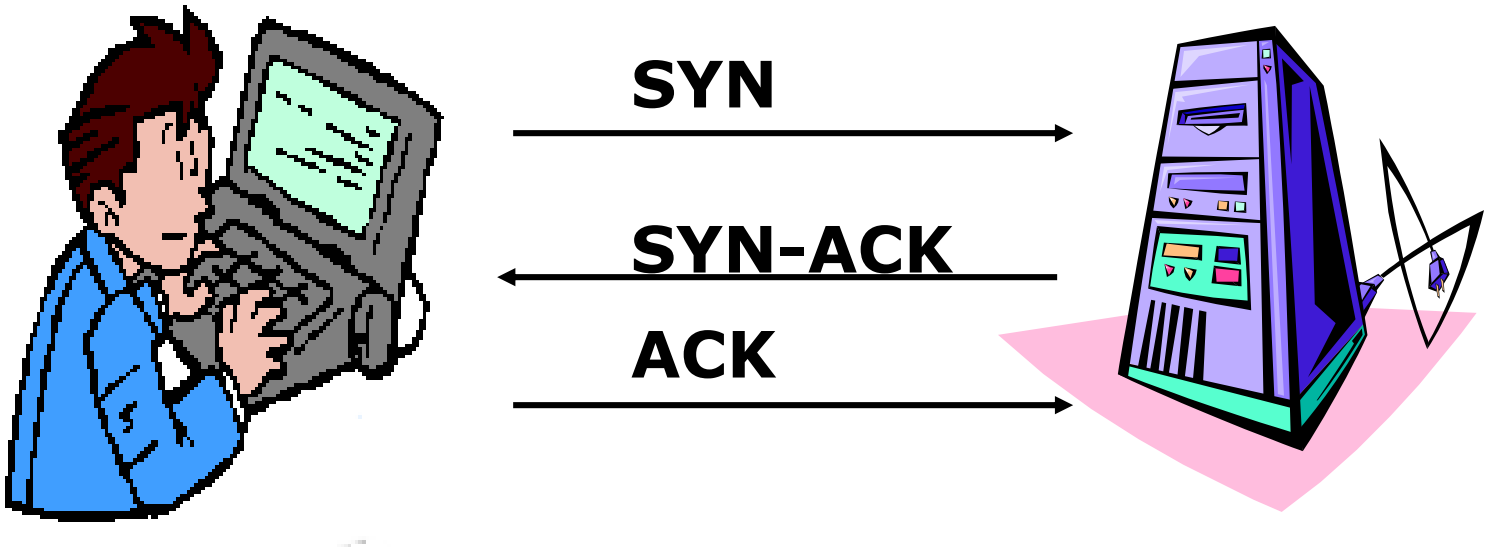
Record for largest DDoS attack

December 2015: 500 Gbps (several – DNS amplification)
January 2016 : 602 Gbps against BBC
21.Sep 2016: 665 Gbps against Brian Krebs
24. Sep 2016: 1Tbps (1000 Gbps) against Brian Krebs
25. Sep 2016: 1.1 Tbps against OVH (hosting provider)
February 28. 2018: 1.35 Tbps against GitHub

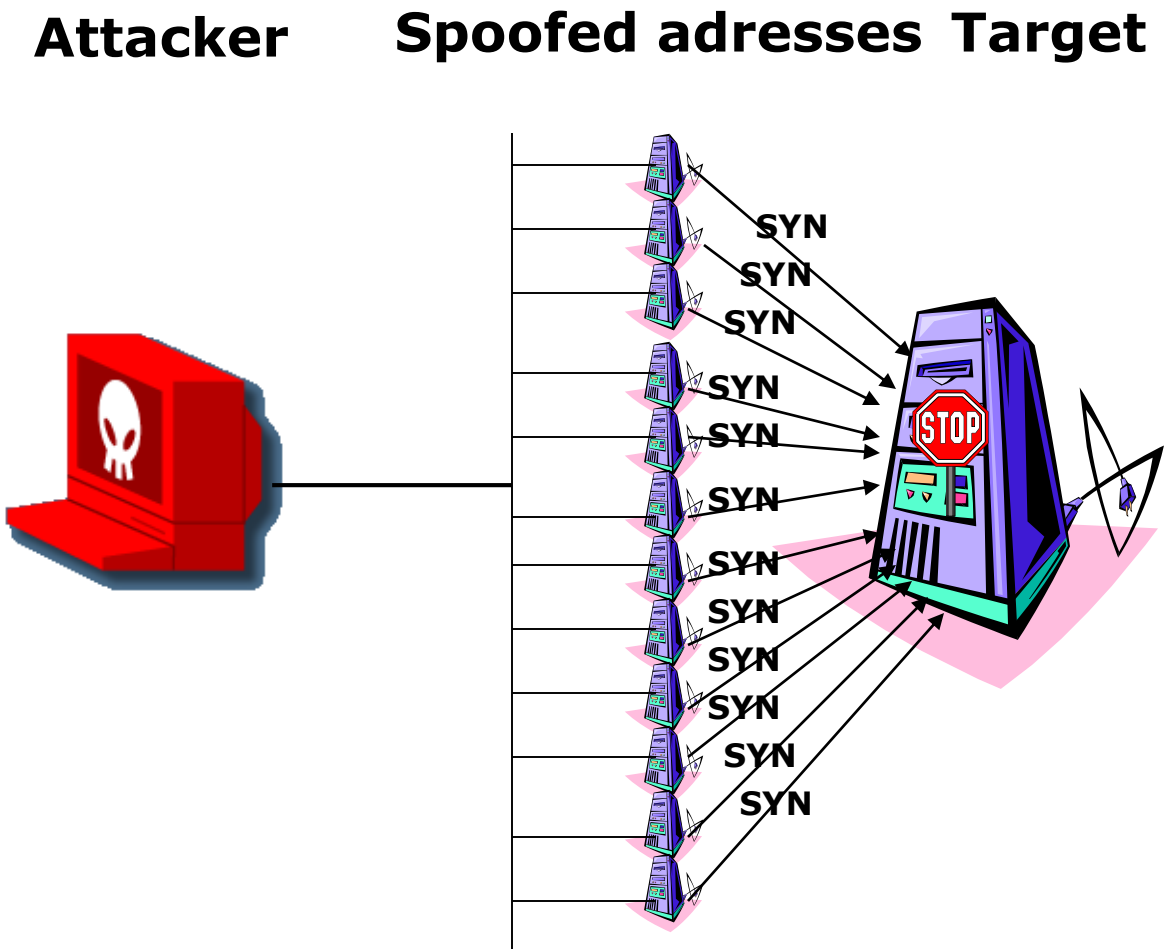
Internet of Things…

Other common flood-techniques

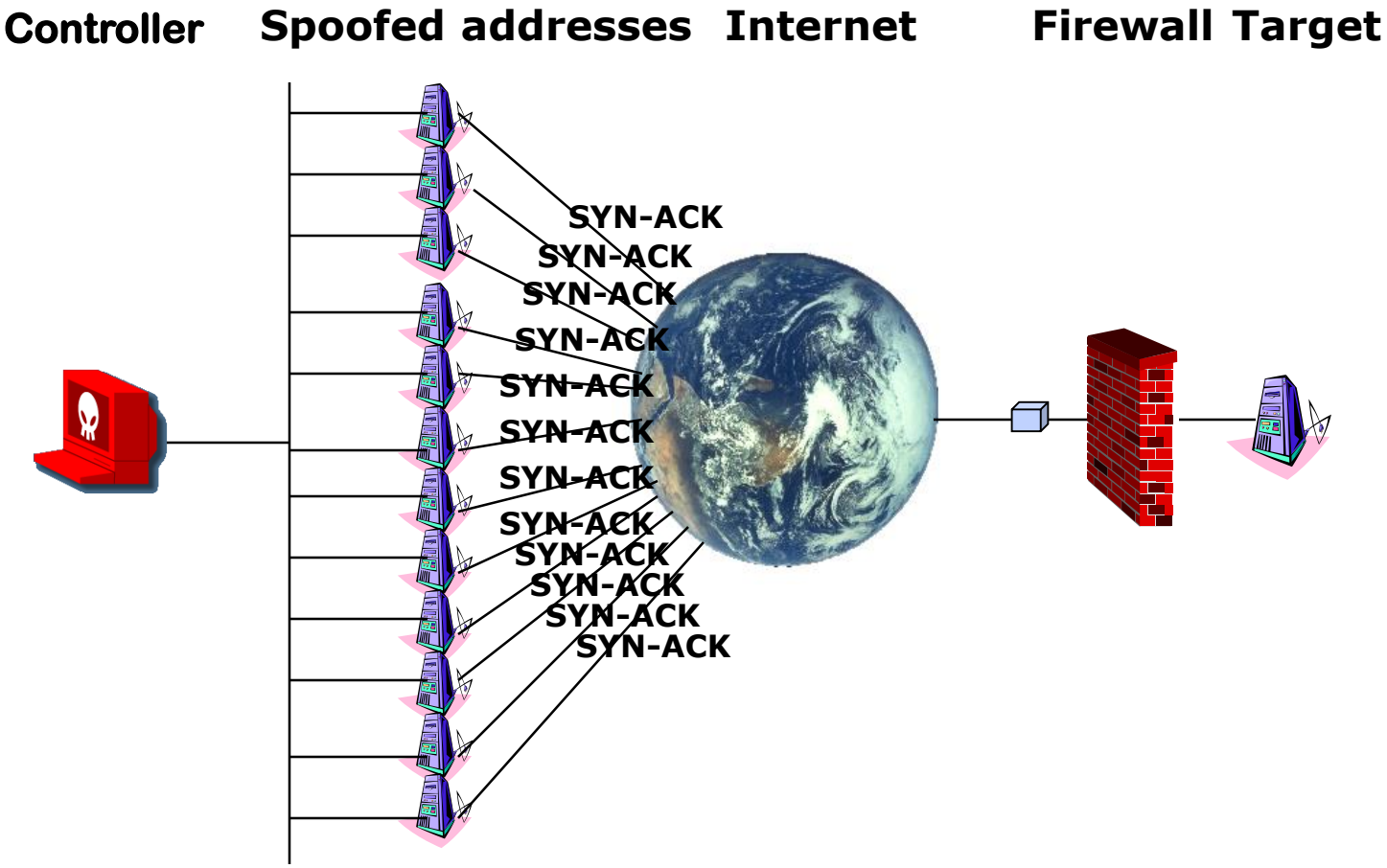
3-way handshake:



SYN-flood:


Attacker
Spoofed adresses
Target
SYN
SYN
SYN
SYN
SYN
SYN
SYN
SYN
SYN
SYN
SYN
STOP

Stream Attack



Reflection attack

Spoofed SYN-ACK flood - uses **CPU** on target computer **AND bandwidth:**

In addition to flood of SYN-ACK packets, target sends TCP RST to non-existent IP-addresses.

Routers will then send back 'ICMP host/network unreachable' adding to bandwidth consumption

Not amplification, this type is known as **reflection attacks**

Spoofing

DoS and DDoS often use spoofed traffic to target, including spoofed source IPs

Random attack source IPs looks like real SYNs.

Source IP spoofing looks as if attack is coming from virtually infinite number of sources

Since packet data can be fully randomized upstream IP filtering techniques is generally useless

Spoofing

UDP and ICMP attacks are most popular since they don’t require a handshake and therefore works well with spoofed source address

Attackers not interested in receiving responses to the requests they send - the packets do not have to be accurate or correctly formatted

Other ‘flag’ and ‘header’ flooders

ACK-flood

RST-flood

NULL-flood (like SYN-flood, but with TCP flags set to 0)

Random flag-flood

Random TCP-headers flood

IP-header flood

Fragment-flood

Mixed-flood attacks

Application DDoS (Layer 7 attacks)

Application DDoS

Focus is focus on specific characteristics of web applications that create bottlenecks

HTTP POST/GET targets logical resources, not CPU or network

Sends a complete, legitimate HTTP POST header, including a 'Content-Length' field to specify size of message body to follow.

Attacker then sends message body slowly (1 byte/110 seconds).

Entire message is correct and complete - target server will obey the 'Content-Length' field in header: waits for the entire body of the message

Attacker establishes hundreds or thousands of connections ->

using all resources for incoming connections on victim

Slow Read

Slow reading attacks advertise a very small number for the TCP Receive Window size while emptying clients' TCP receive buffer slowly.

That naturally ensures a very low data flow rate.

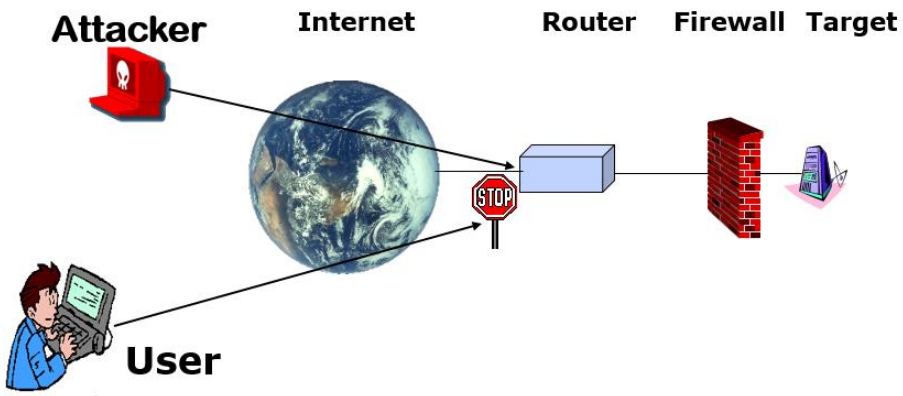
Slow Read attacks then sends packets slowly across multiple connections.

Apache opens a new thread for each connection, and since connections are maintained as long as there is traffic being sent, an attacker can overwhelm a web server by exhausting its thread pool relatively quickly.

Slow Read and HTTP POST/GET – no spoofing

These types of attack bypass flood protection proxies but:

The attacker can no longer spoof or use random source IPs
This reveals location of the bot zombies and *proxies can then block or rate-limit bots*



DoS/DDoS defence

DoS consequences

Attacking specific (web)servers or the entire company infrastructure including DNS and mail.

Datacenters and core internet components.

Sometimes DDoS attacks leads to colateral damage – ISP hosting DNS-servers often victim to Target DNS-floods because of random source IP addresses

Use your risk assessment knowledge

Consider the consequences of a DDoS-attack, what would happen?

Consider your setup, would an attacker be able to DoS more than is actually necessary ?

Consider how an attacker would identify which addresses they need to attack.

Defence

- On-site
- ISP
- Upstream filtering services (scrubbers)

Threat Analysis and Risk Assessment

Defence

Magic packets: Patch OS and applications - if possible

Onsite boxes and applications

Is it possible to block traffic from outside Denmark?

Only forward established TCP connections to site/network

Flooding attacks are difficult — if not impossible — to mitigate with an on-premise solution

Defence

Global networks of scrubbing centres

Junk packets are dropped by proxy/scrubber

Filtering - drop unmatched ACKs, malformed packets etc.

Global load-balancing

Defence

The world's largest DDoS attack took GitHub offline for fewer than 10 minutes

Jon Russell @jonrussell / 7 months ago

Comment

GitHub called in assistance from Akamai Prolexic, which rerouted traffic to GitHub through its "scrubbing" centers, which removed and blocked data deemed to be malicious. Following eight minutes of the assault, the attackers called it off and the DDoS stopped.

In total, GitHub was offline for five minutes between 17:21 to 17:26 UTC, with intermittent connectivity between 17:26 to 17:30 UTC.

Defence against Layer 7 attacks

JavaScript computational challenge tests

Real visitors are allowed to access the site after verification as legitimate

Defence

CAPCHAs per source IP address verifies that the visitor is a human

Web application firewalls
Cookie challenges

Defence

General changes across networks on the Internet

Smurf is almost removed today:

Routers blocks ICMP relay from broadcast addresses and
Firewalls are default configured to block external ICMP packets to broadcast addresses

Defence

Tracebacks

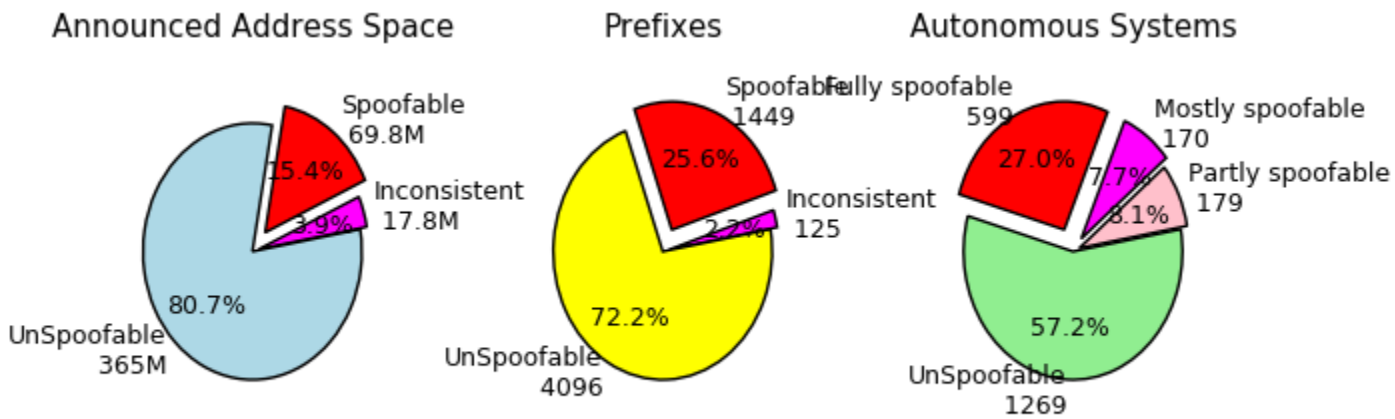
Source IP identification to block attacks at the source

Since DDoS uses spoofed source IPs the ISPs must implement ingress filtering to only forward packets with legitimate source IPs

Defence

ISPs should drop all spoofed packets
But all ISPs must do this

No defense if just 10% of ISPs does not implement
No incentive for deployment



Defence

Core Internet redesign (many good proposals)

Pause

Hardware hacking

Hvad kan man gøre med fysisk adgang til hardware?

(kort introduktion)

Fysisk adgang til hardware

Hardware er selvfølgelig grundlaget for software, algoritmer og kommunikation.

Hardware skal sikre, at kun den autentificerede bruger har adgang til processoren.

Men:
Hardware design har normalt ikke sikkerhed som et nøgle designmål.

Hardware bliver ofte det svage led i sikre systemer.

Fysisk sikkerhed er mange forskellige ting

HOWTO defeat a sliding chain lock with a rubber band:
http://www.youtube.com/watch?v=7INIRLe7x0Y

Locked suitcase:
https://www.youtube.com/watch?v=G5mvvZl6pLI

Opening a computer lock cable:
http://www.youtube.com/watch?v=TPDgX9P8xLQ

Cykellås:
http://www.youtube.com/watch?v=_2vLtpVPqhI

Bypassing security meassures

Tre niveauer

- Software
- Firmware
- Hardware

Fysisk sikkerhed er mange forskellige ting

Evil Maid attacks

Towards the cloud – and beyond

Many To One

Mange brugere
En enkeltstående
central server

I forgårs

One To One

En bruger
En computer

I går

One To Many

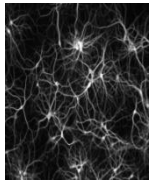
En bruger
Mange medier

I dag

Machine To Machine

Many To Many

I morgen



I over-morgen

Retweeted by the grugq
Matt Haughey @mathowie · 13 hrs
What am I doing? Oh just waiting for my garage door opener to join WiFi so I can get back into my house #2014problems
Verizon
9:51 AM
62%
Places
PLACE
Garage Door Opener
No Response
MyQ Server not responding. Please try again later.
OK

Why defend hardware?

Kan enheder klones? (økonomisk tab pga salg af kopi-enheder, risiko for negative omtale fordi folk tror enhederne er ægte osv)

Kan softwaren stjæles?
Kan hardware design stjæles?
Kan angriber ændre funktionalitet?

Hvor stort budget har angriberen, hvor motiverede er de, kan angriber ødelægge enheden?

Rejsekort – bilnøgler - militære enheder
Supply chain verification

People will have physical access to the hardware

Smart cards, phones, cars, RFID, TV etc., etc…

Software

Firmware updates

RAM dump (keys, credit card info etc)

So what can you do to test or assess hardware?

Fysisk adgang til hardware

1. Design walk-through:
High level impression (messy, professional, hidden)

ChipWorks, iFixIt etc. take apart many types of hardware
Can be good starting points, otherwise time for desoldering components - and Google

2. Find interaction points - explore with a multimeter to catalogue hardware interaction points and potential debug interfaces.

Fysisk adgang til hardware

Mass produced hardware needs to be tested prior to deployment.

Interesting or problematic areas of the board have testing points exposed on the outer layers so external testing machines quickly can validate them on the production line.

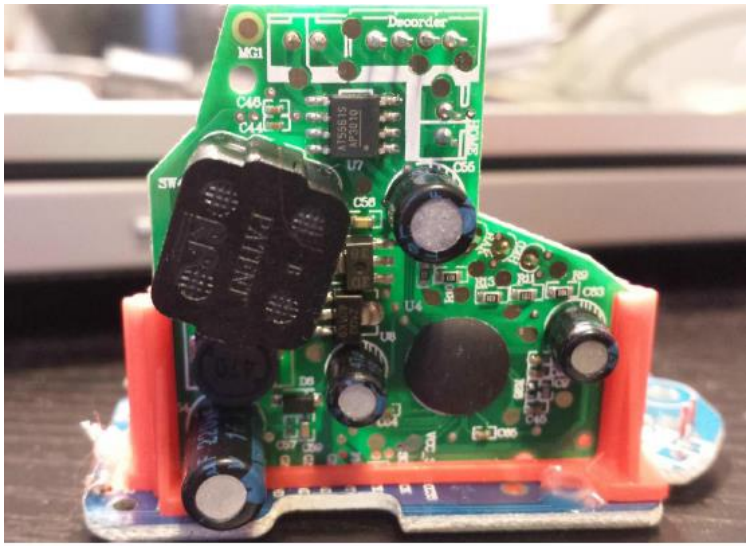
Hardware designers tend to expose debug functionality with these interaction points to allow for firmware and OS flashing post production.

Fysisk adgang til hardware

Tracing all the pins and attempting to recreate the full schematic.
Then acquire spec sheets for every piece of silicon

Start looking for **debug or flashing capabilities**.
The main focus of this part of a hardware analysis is to plan an **attack to grab the resident firmware (or ram)**.

Also explore the USB side of the hardware and look at an available driver/os/kernel

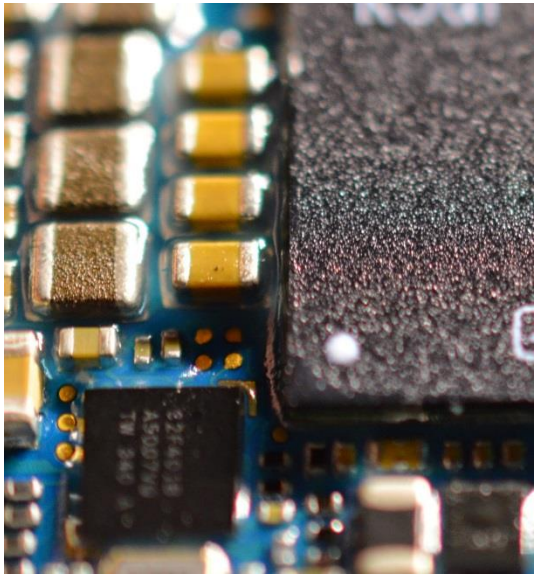


Fysisk adgang til hardware

What we really care about is:

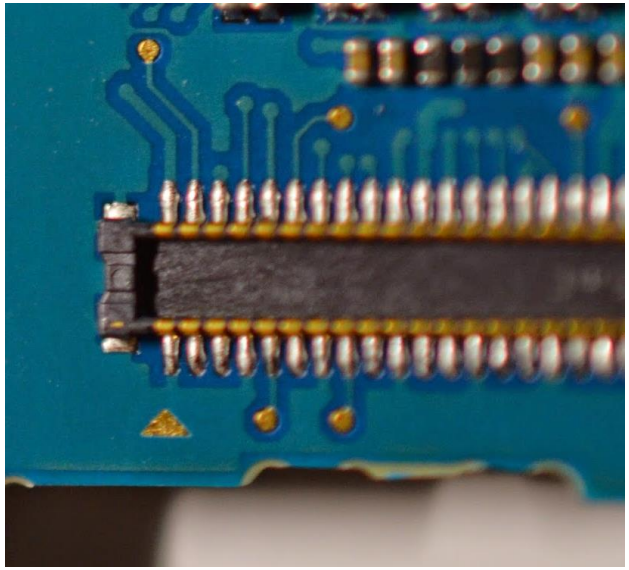
- What components are being used
- How was the device built
  Did the designers leave any debugging mechanisms exposed or active during production
- Are there any weak parts of the design that look easily exploitable

Fysisk adgang til hardware



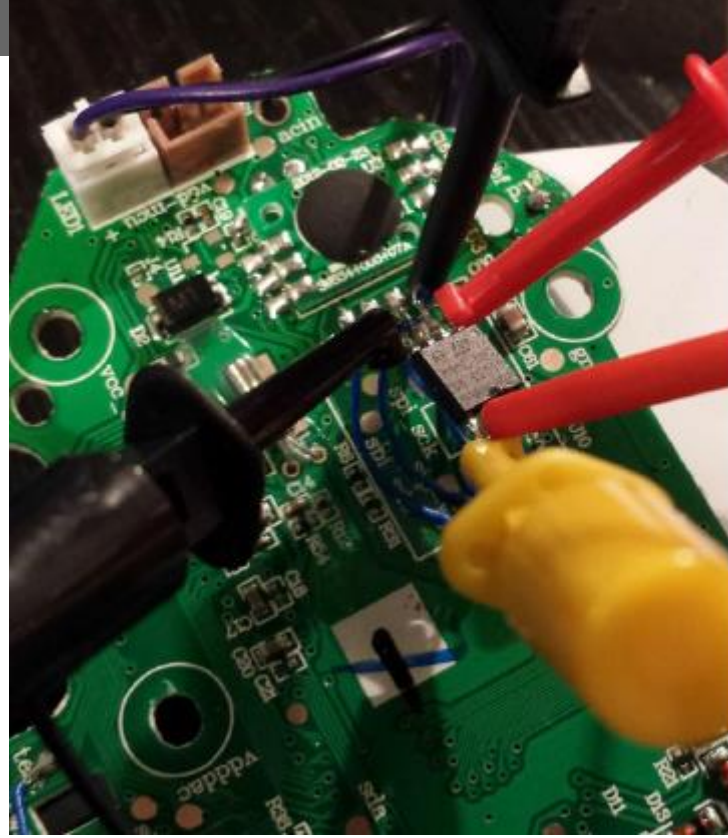
The device must be loaded with software and most vendors protect that functionality with a series of hardware flags controlled by resident voltages. Tracing the pads with a multimeter to see where the missing discrete components would effect, and what circuit they could complete if bridged.

Fysisk adgang til hardware



Ribbon cable seat. The pinouts can be latched with a logic analyzer to watch all the data pass over the cable is possible - much easier than tapping the cables directly.

Fysisk adgang til hardware



Nintendo Wii
Tweezer hack –> private keys

Buffer overflow in save system of Legend of Zelda: Twilight Princess:

Using a modified save file containing a name for Link's horse long enough to cause a buffer overflow pointing to a memory address which contained the loader code.

APP

Side-channel attacks

What else can I do with the device?

Side-channel attacks

Can successfully reveal the secret cryptographic keys stored in secure systems

These attacks include:

- power analysis,
- timing attacks, and
- electromagnetic attacks

Fysisk adgang til hardware

Extracting the Private Key from a TREZOR with a 70 $ Oscilloscope

http://johoe.mooo.com/trezor-power-analysis

Hardware hacking

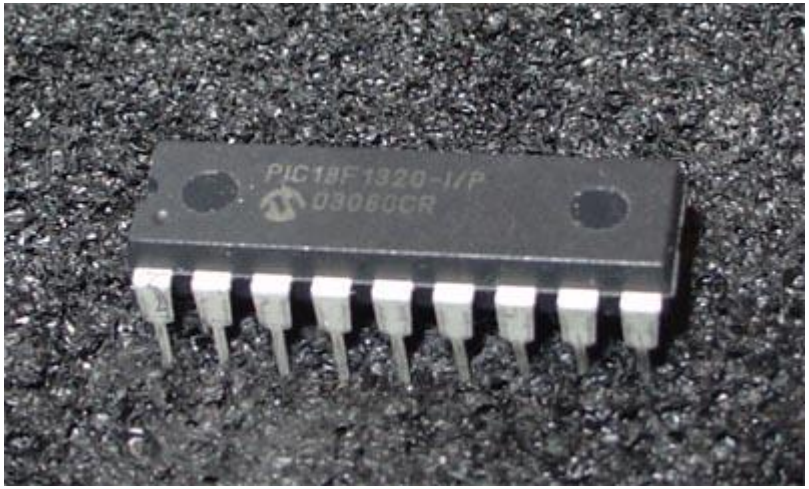
Physically attacks against the chip to extract the key

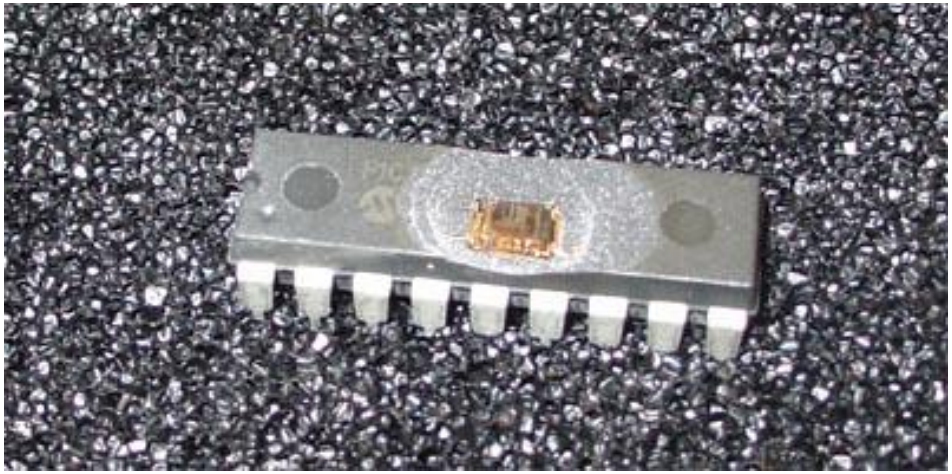
30.000 dollars for "real" microskope, but still not unrealistic

A chip can get cappet for less than 80 dollars on the internet + 600 dollars for an adequate microskope

Decapping chips with acid

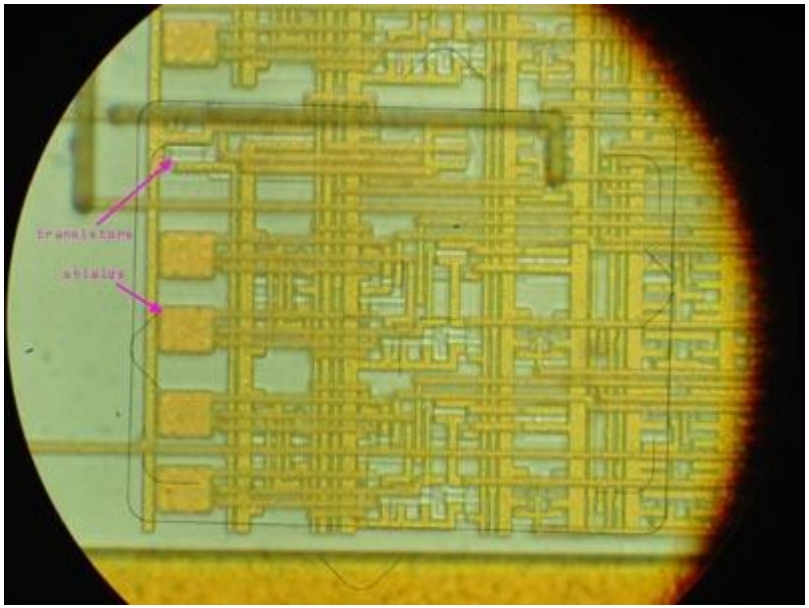
Microskope
Probe when the chip has power

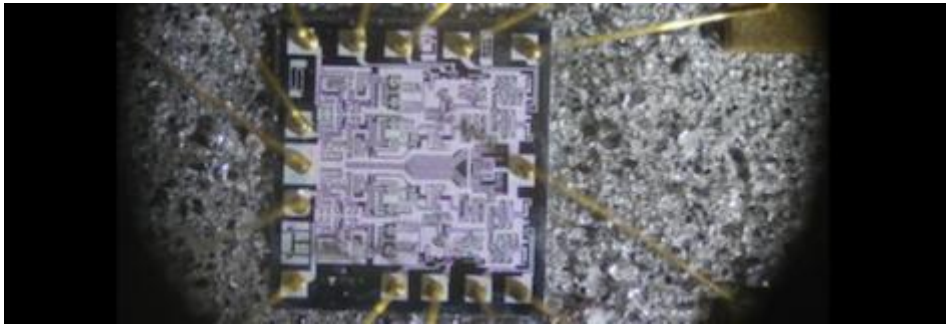




Decapping chips with acid

Microskope
Probe when the chip has power

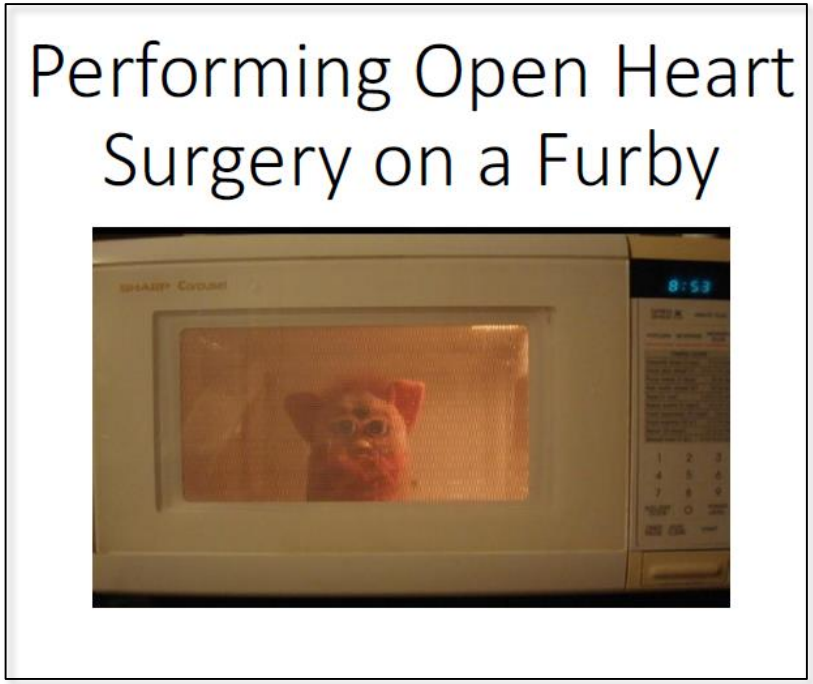




Decapping chips with acid

Microskope
Probe when the chip has power

Hardware hacking – a couple of starting points



http://recon.cx/2014/slides/Performing%20Open%20Heart%20Surgery%20on%20a%20Furby%20Recon%202014.pdf

http://www.siliconpr0n.org/

IoT Security

What is IoT/Internet of Things?

Millions of devices
Communication and protocols - NB-IoT, LoRa, Sigfox, etc. - or Zigbee, RFID, WiFi

Simple, cheap: sensors, meters (smart parking, pet-tracking, temperature, humidity, intelligent meters, asset tracking etc.)

Fast, expensive: Smart cars, smart homes/consumer electronics, CCTV/cameras, healthcare, TV etc.

Smart city, Industry 4.0, Smart Agriculture

Cows/pigs/bees, bicycles, fire alarms, smart bin, street light, environment/pollution/noise, etc., etc.

Is IoT/Internet of Things secure?

Threat modeling – the 5 questions

1. What do you want to protect?
   Assets
2. Who do you want to protect it from?
   Adversaries and threats
3. How likely is it that you will need to protect it?
   Probability
4. How bad are the consequences if you fail?
   Risk
5. How much trouble are you willing to go through in order to try to prevent those?
   Value

The risk assessment (Security Management lecture on Oct. 10th)

What is IoT/Internet of Things?

1. What do you want to protect?
   Assets

Describe the specific solution

Consider your viewpoint:
- User
- Vendor/developer
- Customer
- State/global
- …

What is IoT/Internet of Things?

1. What do you want to protect?
   Assets

You are responsible for security in a Danish company. A number of burglaries have taken place at night at other companies, and management want to improve physical security on all your locations.

Currently a guard company checks (almost) every night if doors and windows are closed.

Your suggested solution will use 2 IoT-solutions:

What is IoT/Internet of Things?

1. What do you want to protect?
   Assets

1) Small sensors on all windows and all doors will check every hour if closed. If open an alarm is sent from device, through company network, to the monitoring system (cloud-based).

2) 4K video cameras are placed outside the building and inside in every office covering all rooms, including kitchen and toilets.
   Video-feed is streamed over the internet to a monitoring system, AI will automatically send an alarm if suspicious behavior is detected.

What is IoT/Internet of Things?

1. What do you want to protect?
   Assets

If alarm is received video can be watched and/or a guard can be sent on site. Police can be called, if necessary.

100 devices

10.000 devices

IoT/Internet of Things - Threats?

1. What do you want to protect?
   Assets

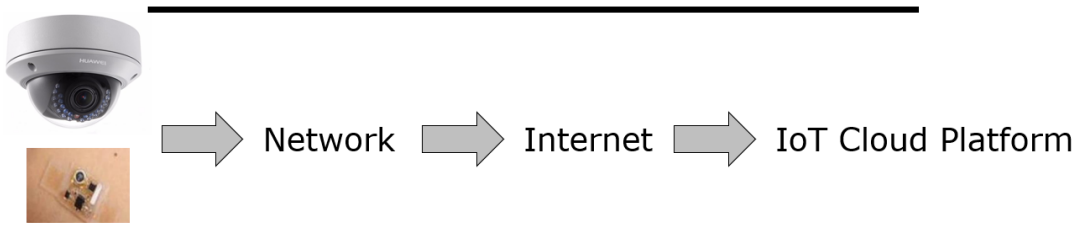
10.100 devices

→ Network → Internet → IoT Cloud Platform

What is IoT/Internet of Things?

2. Who do you want to protect it from?
Adversaries and threats

- Battery or power… Computer or simple chip…
- Low-cost devices cannot support standard security technologies like virus protection or anti-malware
- Physical access to devices, many devices



IoT/Internet of Things - Threats?

- Devices on company network - or directly on Internet?
- Large attack-surface: protocols, devices, platforms etc.
- Privacy
- Upgrades
- IoT-provider security

Devices → Network → Internet → IoT Platform

CIA

CIA

Confidentiality
Integrity
Availability

Fortrolighed – Integritet - Tilgængelighed

Confidentiality

IoT/Internet of Things - Threats?

Encryption (transport and local)
Authentication

Attacks against cloud platform and services

Confidentiality

IoT/Internet of Things - Threats?

IoT insecurity: Casino hacked through smart thermometer

Hackers stole a casino's high-roller database through a thermometer in the lobby fish tank

OSCAR WILLIAMS-GRUT | APR 15, 2018, 12.42 PM

Facebook Linkedin WhatsApp Twitter Google+ Reddit

Integrity

IoT/Internet of Things - Threats?

Trust the sensors/data?

Availability

IoT/Internet of Things - Threats?

DoS/DDoS risk?

Availability risks?

IoT/Internet of Things - Threats?

Computer og strøm

- PKI
- VPN
- Security upgrades
- Anti-virus/anti-DoS

Chip og batteri

- Lightweight authentication/PSK
- Lighweight encryption (only important data)

Physical security

Hvad er den største trussel imod US infrastruktur

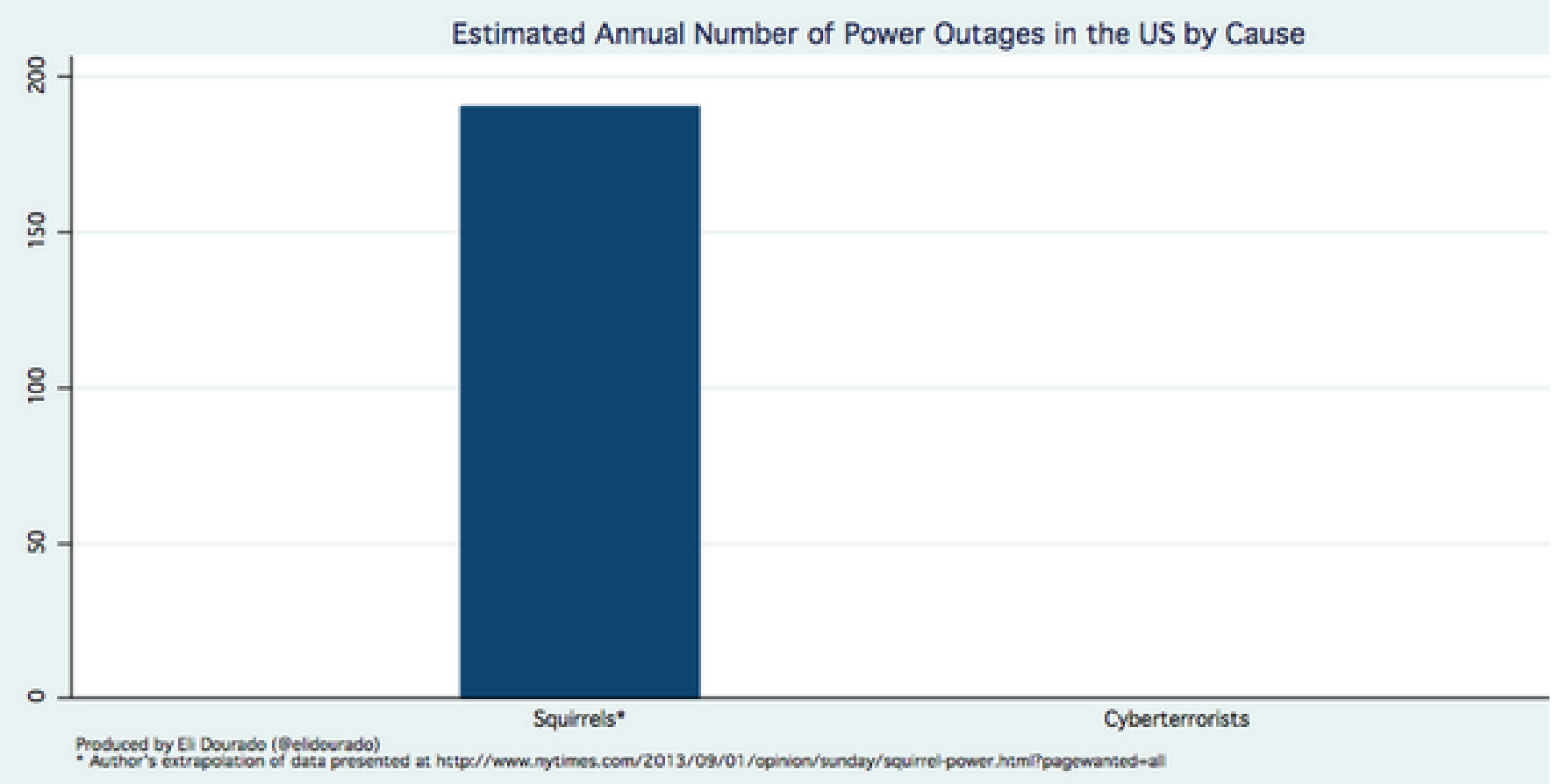
Forget hackers: Squirrels are a bigger threat to America's power grid

Who needs fancy military-grade equipment when nimble legs and sharp incisors will do?

By Eugene K. Chow | January 28, 2014 15

http://www.nytimes.com/2013/09/01/opinion/sunday/squirrel-power.html?pagewanted=all&_r=0

Hvad er den største trussel imod US infrastruktur



Fysisk sikkerhed og IT Sikkerhed

Hvad er forbindelsen til IT-sikkerhed?

CIA

Confidentiality
Integrity
Availability

Fortrolighed – Integritet - Tilgængelighed

Availability Policies

Until recently, researchers ignored availability, but it's where the money goes

	Research	Industry
Confidentiality	90%	1%
Integrity/authenticity	9%	9%
Availability	1%	90%

Fysisk sikkerhed – Drop Table

Fysisk sikkerhed – andre overvejelser

Deter – Detect – Alarm – Delay - Respond

Hegn
Døre
Kamera
Video
Vinduer
Strømtavler
Fysisk placering
…

Som alt anden it-sikkerhed: Threat analysis, design the system (equipment and procedures) Then test it

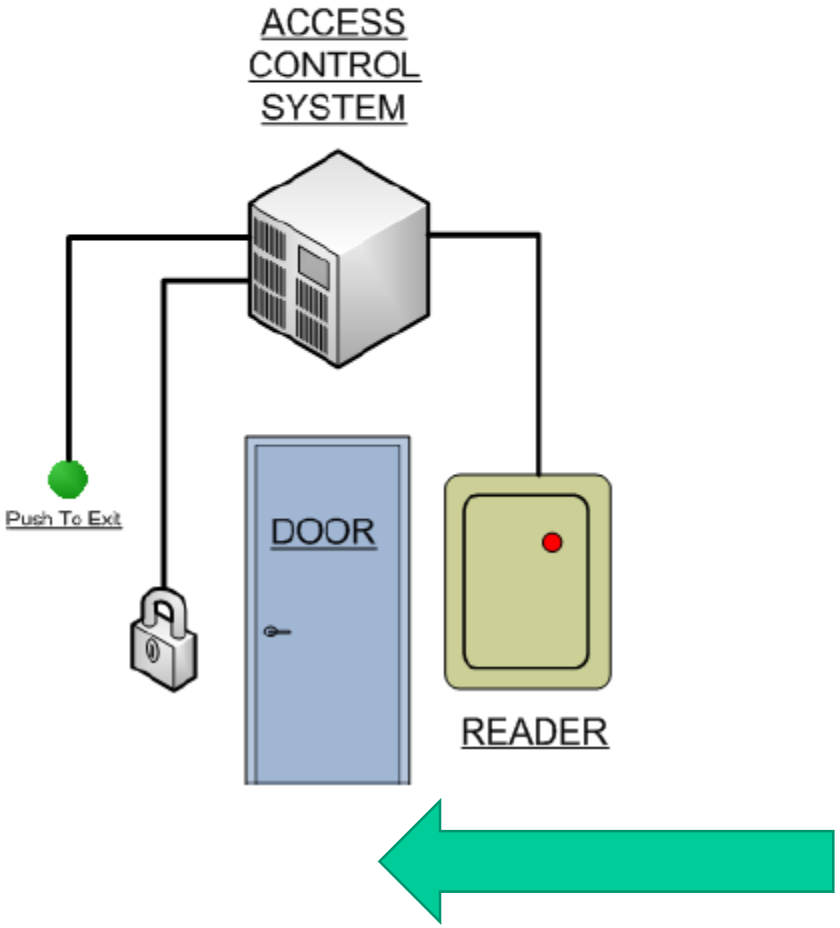
Fysisk sikkerhed – andre overvejelser

Narkoman
Vaneforbryder
Specialist
International professionel

”Standardtyv” metoden

Basic system

Placering af "request to exit" knapper er kritisk, kan de aktiveres ude fra?



Placering af serverrum

Dit firma skal bygge et helt nyt serverrum…
Eksempler på overvejelser?

Checklist

Fysisk sikkerhed

Lastbil og strømforsyning:
http://www.youtube.com/watch?v=M5CZu_XBf70

Flood:
http://www.youtube.com/watch?v=ANU-oSE5_hU

Tyrkiet:
https://www.youtube.com/watch?v=1M_QTBENR1Q

Halon:
http://www.youtube.com/watch?v=2fyGGqgVzCY

Huller i serverrummet:
http://www.youtube.com/watch?v=sBENKXrxJZI

Kabling og oprydning:
http://www.youtube.com/watch?v=r-9VZubB1uI

?